

Ciberseguridad

Auditoría de seguridad de la información y gestión de riesgos

EPS Sanitas (Grupo Keralty) — ISO/IEC 27001:2022 e ISO 31000:2018

Yslen Natalia Moreno Gutierrez
Maria Belen Peña
Laura Sophia Hernandez

Universidad Sergio Arboleda
Escuela de ciencias exactas e ingeniería
Bogotá D.C., 20 de octubre de 2026

Índice

Introducción **5**

1. Reglas internas de seguridad **5**

1.1. Explicación de cada regla 6

2. Inventario de activos de información **7**

2.1. Escalas utilizadas 8

2.2. Activos identificados 8

2.3. Descripción y justificación de cada activo 9

3. Identificación de vulnerabilidades **13**

3.1. Referencias y escala utilizadas 13

3.2. Resumen de vulnerabilidades por activo 14

3.3. Detalle de las diez vulnerabilidades con CVE 16

3.4. Detalle de las cuatro vulnerabilidades sin CVE 22

4. Análisis y evaluación de riesgos **24**

4.1. Escala de probabilidad 24

4.2. Escala de impacto 25

4.3. Matriz de nivel de riesgo 26

4.4. Identificación de riesgos 26

4.5. Valoración de riesgos (riesgo inherente) 28

5. Matriz de evaluación y tratamiento del riesgo **30**

5.1. Matriz A: riesgo, activos, amenaza y vulnerabilidades 31

5.2. Matriz B: controles, tratamiento y riesgo residual 32

6. Mapa de calor **36**

6.1. Mapa de calor del riesgo inherente 36

6.2. Mapa de calor del riesgo residual 37

7. Plan de tratamiento de riesgos **38**

8. Caso de incidente: ransomware **43**

8.1. Escenario 43

8.2. Cadena del ataque y plan que la habría cortado 43

8.3. Respuesta al incidente 44

9. Conclusiones **45**

Referencias **47**

Índice de tablas

1. Resumen de las reglas propuestas. 5
2. Escala de clasificación de la información (propuesta del equipo). 8
3. Inventario de activos de información (ficticio). 8
4. Valores de las métricas CVSS v3.1. 14
5. Las 14 vulnerabilidades identificadas. 15
6. Escala de probabilidad. 24
7. Escala de impacto. 25
8. Matriz de nivel de riesgo. 26
9. Acción según el nivel de riesgo. 26
10. Identificación de riesgos. 26
11. Valoración de los riesgos inherentes. 28
12. Plazos según el nivel de riesgo inherente. 30
13. Matriz A: evaluación del riesgo inherente. 31
14. Matriz B: tratamiento y riesgo residual esperado. 33
15. Mapa de calor del riesgo inherente (antes del tratamiento). 36
16. Mapa de calor del riesgo residual (después del tratamiento). 37
17. Comparación entre riesgo inherente y residual. 37
18. Cronograma del plan por fases. 42
19. Cadena del ataque y controles del plan. 43
20. Resumen de la respuesta al incidente. 45

Introducción

Este informe presenta un análisis de seguridad de la información de EPS Sanitas (Grupo Keralty), realizado como si el equipo fuera un auditor externo: se identifican activos, vulnerabilidades y riesgos, y se proponen medidas de tratamiento con base en la ISO/IEC 27001:2022 y en el proceso de gestión de riesgos de la ISO 31000:2018.

El análisis se apoya en información pública verificable de la empresa, principalmente en dos documentos:

- **D1:** Política de Privacidad y Tratamiento de Datos Personales del Grupo Keralty (última modificación: 13/02/2024).
- **D2:** Política corporativa de seguridad de la información y ciberseguridad, versión 1.0 (08/07/2021), con sus políticas específicas (identificadas como PL en este informe).

Como la información interna de la EPS no es pública, el inventario de activos, las tecnologías, los responsables y algunas debilidades son **supuestos ficticios del equipo**, y se identifican como tales a lo largo del documento. En ningún caso se afirma que la EPS sea vulnerable, y no se realizó ninguna prueba intrusiva ni escaneo sobre sus sistemas.

1. Reglas internas de seguridad

Se formularon ocho reglas nuevas para la EPS. Cada una se justificó, se relacionó con los controles del Anexo A de la ISO/IEC 27001:2022 y se verificó por palabras clave en D1 y D2 que no estuviera contemplada explícitamente; cuando el tema aparece de forma general, se indica como *cobertura parcial* y la regla se limita al elemento ausente.

La tabla completa, con el enunciado, la justificación y la verificación de búsquedas de cada regla, está en el Anexo A. La siguiente tabla resume las reglas, sus controles y el resultado de la búsqueda.

Tabla 1: Resumen de las reglas propuestas.

Código	Regla	Controles del Anexo A	Resultado de la búsqueda en D1 y D2
REG-SI-01	Autenticación segura: contraseñas generadas y autenticación multifactor	A.5.17, A.8.5, A.8.2, A.5.16	Sin coincidencias sobre MFA ni contraseñas de usuario; PL05 trata el control de acceso solo en términos generales.

Código	Regla	Controles del Anexo A	Resultado de la búsqueda en D1 y D2
REG-SI-02	Seguridad en el uso de servicios en la nube	A.5.23, A.5.19, A.5.20	D1 menciona la nube solo como finalidad; D2 sin coincidencias (PL11 trata proveedores en general).
REG-SI-03	Uso exclusivo de herramientas y canales autorizados para información personal y de salud	A.5.10, A.5.14, A.8.12, A.5.34	Sin coincidencias; PL04 y PL09 hablan de uso aceptable sin precisar herramientas ni canales.
REG-SI-04	Enmascaramiento de datos en pruebas y análisis	A.8.11, A.8.33, A.5.34	Cobertura parcial: PL10 menciona “datos de prueba” sin exigir enmascaramiento.
REG-SI-05	Monitoreo y alertas de accesos a historias clínicas y datos de salud	A.8.15, A.8.16, A.5.15, A.5.18	Cobertura parcial: PL08 menciona el registro de operaciones, sin alertas ni revisión periódica.
REG-SI-06	Protección de la información en el puesto de trabajo y fuera de las instalaciones	A.6.7, A.7.9, A.7.7, A.8.1	Sin coincidencias; PL07 cubre solo la seguridad física dentro de las instalaciones.
REG-SI-07	Control de acceso físico con credencial a sedes y áreas no públicas	A.7.1, A.7.2, A.7.3	Cobertura parcial: PL07 habla de “áreas seguras” sin definir credencial ni registro de visitantes.
REG-SI-08	Protección reforzada de áreas críticas (centro de datos, cuartos técnicos y archivo)	A.7.2, A.7.4, A.7.8	Cobertura parcial: “centro de datos” sin coincidencias; PL07 es genérica.

1.1 Explicación de cada regla

REG-SI-01: Autenticación multifactor y contraseña segura. La regla atiende la autenticación completa: la contraseña no la inventa la persona (la genera y la guarda una herramienta, como hacen los gestores de Google, Apple o Microsoft) y, en los accesos más delicados, se exige además un segundo factor. Si alguien roba una contraseña, todavía le falta el segundo factor.

REG-SI-02: Servicios en la nube. Antes de guardar información de afiliados en la nube de un tercero, la EPS debe revisar quién la protege, dónde está almacenada y cómo la recupera o la borra si termina el contrato. Las políticas permiten usar la nube, pero no explican cómo se evalúa un proveedor.

REG-SI-03: Herramientas y canales autorizados. Evita que los datos personales salgan de las herramientas que la empresa controla. Cubre dos casos: pegar datos de un afiliado en una IA pública para que redacte un resumen, y mandar una fórmula médica por el WhatsApp personal. Las políticas

hablan de “uso aceptable”, pero no mencionan la IA ni los canales permitidos.

REG-SI-04: Enmascaramiento de datos. Las pruebas de software y los análisis estadísticos no deberían usar datos reales de personas. Se reemplazan por datos alterados (por ejemplo, nombres y cédulas ficticias que conservan el formato). Las políticas mencionan los “datos de prueba”, pero no exigen disfrazarlos.

REG-SI-05: Monitoreo de accesos a historias clínicas. Que alguien consulte una historia clínica sin necesitarlo para su trabajo (por curiosidad o por un familiar) es una de las fallas más difíciles de detectar. Esta regla pide dejar registro de cada consulta, generar alertas ante patrones raros (muchas consultas, horarios extraños, pacientes sin relación con el funcionario) y revisar los accesos cada trimestre. Hoy se menciona el registro de operaciones en general, pero no esta revisión específica.

REG-SI-06: Puesto de trabajo y fuera de las instalaciones. Aplica la misma protección dentro y fuera de la oficina. Si un colaborador atiende llamadas desde su casa, debe hacerlo en un espacio donde nadie escuche, usar el equipo autorizado y conectarse por VPN. Si se levanta de su puesto, bloquea la pantalla y no deja papeles con datos a la vista. La política actual cubre la seguridad física de las instalaciones, pero no estos escenarios.

REG-SI-07: Credencial para entrar. Sigue la lógica de un hospital y se aplica a las áreas no públicas. La bata o el uniforme no cuentan como identificación, porque cualquiera puede conseguirlos. Los visitantes reciben una credencial temporal y van acompañados.

REG-SI-08: Protección de áreas críticas. Protege el centro de datos, los cuartos técnicos y el archivo de historias clínicas con control electrónico, registro de cada ingreso, acompañamiento de terceros y cámaras.

2. Inventario de activos de información

La política SIG-SI-PL04 de D2 obliga al Grupo Keralty a mantener un inventario de activos y a clasificar la información, pero el inventario real de la EPS no es público. Por eso el siguiente listado es **ficticio**: se construyó según el funcionamiento normal de una EPS en Colombia. Los responsables y las tecnologías mencionadas (Microsoft, Fortinet, Cisco, VMware, Veeam, AMI, Intel, AMD, APC y Hikvision) son supuestos del equipo.

Se escogieron 10 activos de distintos tipos: información, software, infraestructura tecnológica, hardware, personas e infraestructura física. Se incluyó un activo físico (las instalaciones, con su respaldo eléctrico y su control de acceso) porque la información de una EPS no solo se protege con controles informáticos: si se va la luz en una sede, si cualquiera puede entrar al cuarto donde están los routers o si una persona con bata llega hasta un consultorio, la información queda expuesta o deja de estar disponible aunque los sistemas estén bien configurados.

2.1 Escalas utilizadas

Clasificación	Significado
Pública	Información que cualquier persona puede conocer sin causar daño, como la página informativa o las políticas publicadas.
Uso interno	Información para los colaboradores. Si se filtra, causa un daño bajo.
Confidencial	Datos personales o información del negocio que, si se filtra, afecta a personas o a la empresa.
Reservada	Información con protección especial por ley, como las historias clínicas, cuya divulgación causa un daño grave.

Tabla 2: Escala de clasificación de la información (propuesta del equipo).

Los activos físicos y las personas no son información en sí mismos; en esos casos se indica la clasificación más alta de la información que albergan o a la que tienen acceso.

Cada activo se valoró de 1 a 3 en confidencialidad (C), integridad (I) y disponibilidad (D): 1 si el daño es menor y se corrige fácilmente, 2 si afecta procesos internos o a un grupo limitado de personas, y 3 si afecta a muchos afiliados, la atención en salud o el cumplimiento de la ley. La **criticidad** sale de la suma $C + I + D$: de 3 a 5 es Baja, de 6 a 7 es Media y de 8 a 9 es Alta.

2.2 Activos identificados

Tabla 3: Inventario de activos de información (ficticio).

Código	Activo	Tipo	Responsable (supuesto)	Clasificación	C	I	D	Criticidad
ACT-01	Base de datos de afiliados	Información	Jefe de Gestión de Afiliaciones	Confidencial	3	3	2	Alta (8)
ACT-02	Historias clínicas (electrónicas y archivo físico)	Información	Director Médico	Reservada	3	3	3	Alta (9)
ACT-03	Copias de seguridad	Información	Jefe de Infraestructura TI	Reservada	3	3	2	Alta (8)
ACT-04	Portal web y app de afiliados	Software	Jefe de Canales Digitales	Confidencial	2	3	3	Alta (8)
ACT-05	Directorio Activo	Software	Administrador de Plataformas TI	Confidencial	3	3	3	Alta (9)

Código	Activo	Tipo	Responsable (supuesto)	Clasificación	C	I	D	Criticidad
ACT-06	Puesto de trabajo digital (equipos, correo y colaboración)	Hardware / software	Coordinador de Soporte TI	Confidencial	3	2	2	Media (7)
ACT-07	Red de comunicaciones (VPN, firewall, routers, switches)	Infraestructura tecnológica	Jefe de Seguridad de la Información	Confidencial	2	3	3	Alta (8)
ACT-08	Servidores virtualizados	Infraestructura tecnológica	Jefe de Infraestructura TI	Confidencial	2	3	3	Alta (8)
ACT-09	Instalaciones físicas (sedes, centro de datos, cuartos técnicos)	Infraestructura física	Gerente de Infraestructura Física	Alberga hasta Reservada	3	3	3	Alta (9)
ACT-10	Personal clave	Personas	Director de Talento Humano	Acceso hasta Reservada	3	2	3	Alta (8)

2.3 Descripción y justificación de cada activo

A continuación se describe cada activo y se explica por qué se incluyó y cómo se valoró. Los responsables y las tecnologías son supuestos del equipo.

ACT-01. Base de datos de afiliados (Información)

Es la base donde se guardan los datos de identificación, contacto, núcleo familiar y estado de afiliación de las personas inscritas en la EPS. El responsable es el Jefe de Gestión de Afiliaciones (supuesto). La clasificamos como **Confidencial**, porque son datos personales protegidos por la Ley 1581 de 2012. Valoración: C = 3, I = 3, D = 2, total 8, criticidad **Alta**.

La incluimos porque es el corazón del negocio. Sin ella la EPS no sabe a quién atiende. Una filtración expondría a millones de personas, y un dato alterado puede dejar a un afiliado sin servicio. La disponibilidad la pusimos en 2 porque, si la base se cae unas horas, la atención se retrasa pero no se detiene por completo.

ACT-02. Historias clínicas: registro electrónico y archivo físico (Información)

Son los registros de diagnósticos, tratamientos, exámenes y antecedentes médicos de los afiliados. Incluye la historia clínica electrónica y el archivo físico de historias en papel que todavía se conserva en las sedes. El responsable es el Director Médico (supuesto). La clasificamos como **Reservada**, porque la historia clínica tiene reserva legal según la Ley 23 de 1981 y la Resolución 1995 de 1999, y además son datos sensibles

según la Ley 1581 de 2012. Valoración: C = 3, I = 3, D = 3, total 9, criticidad **Alta**.

La incluimos porque es la información más delicada que maneja una EPS. Si alguien la cambia, un médico puede tomar una decisión equivocada. Si no está disponible, no se puede atender bien al paciente. Este activo se relaciona con la regla REG-SI-05 (monitoreo de accesos a historias clínicas) y, en su parte física, con la REG-SI-08, que protege el archivo de historias clínicas con control de acceso reforzado.

ACT-03. Copias de seguridad (Información)

Son los respaldos periódicos de las bases de datos y de los sistemas principales, guardados en almacenamiento local, dentro del centro de datos (ACT-09), y en la nube. El responsable es el Jefe de Infraestructura TI (supuesto). La clasificamos como **Reservada**, porque una copia de seguridad contiene toda la información de los demás activos, incluidas las historias clínicas. Valoración: C = 3, I = 3, D = 2, total 8, criticidad **Alta**.

La incluimos porque los backups son la última defensa ante un ransomware. Si el atacante logra cifrarlos o borrarlos junto con los sistemas, la EPS no tiene cómo recuperarse. A Keralty, el grupo al que pertenece Sanitas, le pasó un ataque de este tipo en 2022. Se relaciona con la REG-SI-02 (copias en la nube) y con la REG-SI-08, que exige que los respaldos locales permanezcan dentro de las áreas críticas protegidas.

ACT-04. Portal web y aplicación móvil de afiliados (Software)

Son los canales digitales donde los afiliados consultan citas, autorizaciones, certificados y resultados. El responsable es el Jefe de Canales Digitales (supuesto). Lo clasificamos como **Confidencial**: aunque una parte del portal es pública, la zona privada muestra datos personales y de salud. Valoración: C = 2, I = 3, D = 3, total 8, criticidad **Alta**.

Lo incluimos porque es lo más expuesto de la empresa: está abierto a internet las 24 horas. Si se cae, miles de afiliados no pueden hacer trámites. Si lo alteran, se pueden publicar datos falsos o usarlo para engañar a los usuarios.

ACT-05. Directorio Activo (Software)

Es el sistema que administra los usuarios, las contraseñas y los permisos de los colaboradores en la red de la empresa (supuesto: Microsoft Active Directory). El responsable es el Administrador de Plataformas TI (supuesto). Lo clasificamos como **Confidencial**, porque guarda credenciales y la estructura de permisos de toda la organización. Valoración: C = 3, I = 3, D = 3, total 9, criticidad **Alta**.

Lo incluimos porque quien toma el control del Directorio Activo controla prácticamente toda la red: puede crear usuarios, darse permisos y entrar a cualquier sistema. Por eso los atacantes lo buscan primero. Se relaciona con la regla REG-SI-01 (autenticación segura), que pide contraseñas generadas por una herramienta y un segundo factor en los accesos más delicados.

ACT-06. Puesto de trabajo digital: equipos de usuario, correo y herramientas de colaboración (Hardware / software)

Reúne lo que cada colaborador usa todos los días para trabajar: los portátiles, computadores, celulares corporativos y memorias USB, junto con el correo, el chat y los documentos compartidos (supuesto: Windows y Microsoft 365). Los agrupamos en un solo activo porque se usan juntos y comparten las mismas amenazas. El responsable es el Coordinador de Soporte TI (supuesto). Lo clasificamos como **Confidencial**, porque por el correo y en los equipos circulan autorizaciones, documentos de afiliados e información interna. Valoración: C = 3, I = 2, D = 2, total 7, criticidad **Media**.

Lo incluimos porque es la principal puerta de entrada de los ataques: un solo clic en un correo de phishing o un adjunto malicioso puede darle acceso a un atacante, y un portátil perdido sin cifrar puede exponer datos de salud. Le dimos criticidad media porque un equipo o un buzón aislado tiene un impacto limitado y la operación sigue por otros medios. Pero son miles de equipos y cuentas, y su riesgo es alto por lo fácil que es atacarlos; eso lo reflejamos en el análisis de riesgos. Se relaciona con las reglas REG-SI-01, REG-SI-03 y REG-SI-06.

ACT-07. Red de comunicaciones: VPN, firewall, routers y switches (Infraestructura tecnológica)

Son los equipos que protegen la frontera de la red, permiten que los colaboradores se conecten desde afuera de forma segura y conectan cada sede con el centro de datos (supuestos: firewall y VPN Fortinet; routers y switches Cisco). Físicamente están instalados en el centro de datos y en los cuartos técnicos de las sedes (ACT-09). El responsable es el Jefe de Seguridad de la Información, con apoyo del Jefe de Infraestructura TI (supuesto). Los clasificamos como **Confidencial**, porque sus configuraciones revelan cómo está armada la red. Valoración: C = 2, I = 3, D = 3, total 8, criticidad **Alta**.

Los incluimos porque, con el trabajo remoto, la VPN se volvió el camino de entrada a la empresa. Si un atacante aprovecha una falla en ella o en un router, entra directo a la red interna o puede espiar el tráfico. Además, si estos equipos se caen, se corta la conexión de sedes y teletrabajadores. Se relaciona con las reglas REG-SI-01 y REG-SI-06, y en lo físico con la REG-SI-08.

ACT-08. Servidores virtualizados (Infraestructura tecnológica)

Son los servidores físicos donde corren, en forma de máquinas virtuales, los sistemas principales de la EPS (supuestos: hipervisor VMware ESXi, procesadores Intel o AMD y controlador de administración remota BMC con firmware AMI). Están instalados en los racks del centro de datos (ACT-09). El responsable es el Jefe de Infraestructura TI (supuesto). Los clasificamos como **Confidencial**, porque alojan los sistemas que procesan información de afiliados. Valoración: C = 2, I = 3, D = 3, total 8, criticidad **Alta**.

Los incluimos porque un solo servidor de virtualización puede alojar decenas de sistemas al mismo tiempo, y porque tienen vulnerabilidades tanto en el software (el hipervisor) como en el hardware (el procesador y el BMC). Los grupos de ransomware los atacan mucho porque, cifrando uno, tumban muchos servicios de una vez. También dependen de que nadie no autorizado llegue físicamente a ellos y de que no se corte la energía.

ACT-09. Instalaciones físicas: sedes, clínicas, centro de datos y cuartos técnicos (Infraestructura física)

Son los edificios donde la EPS atiende a sus afiliados y trabaja su personal (consultorios, áreas administrativas, puntos de atención y archivos), junto con el centro de datos y los cuartos técnicos donde están los racks con los servidores, los routers y los switches. Incluye los elementos que mantienen esos espacios funcionando y protegidos: el respaldo eléctrico (UPS y planta eléctrica, supuesto: UPS APC), la climatización del centro de datos y el sistema de control de acceso físico y videovigilancia (credenciales con fotografía, lectores de tarjeta o biométricos y cámaras, supuesto: Hikvision). El responsable es el Gerente de Infraestructura Física y Mantenimiento, con el Jefe de Infraestructura TI para el centro de datos (supuesto). Como activo físico, **alberga información hasta el nivel Reservada**: ahí están los servidores, el archivo de historias clínicas y los computadores de los consultorios. Además, el propio activo genera datos personales y sensibles: los registros de ingreso y las grabaciones de las cámaras son datos personales (el documento D1 menciona la videovigilancia como finalidad del tratamiento), y las huellas de los lectores biométricos son datos sensibles según la Ley 1581 de 2012, por lo que deben protegerse igual que la información de los afiliados. Valoración: C = 3, I = 3, D = 3, total 9, criticidad **Alta**.

Lo incluimos porque la información de la EPS también depende de los espacios físicos y de su energía, y lo valoramos con el máximo en los tres criterios:

- **Disponibilidad (3):** si se va la luz en una sede y no hay UPS ni planta eléctrica, se apagan de golpe los servidores, los equipos de red y los computadores de los consultorios. Lo mismo pasa si una sede se cierra por una inundación o un incendio: la atención presencial se detiene y los pacientes se quedan sin consultas ni autorizaciones.
- **Confidencialidad (3):** en una clínica conviven pacientes, acompañantes, proveedores y personal. La bata o el uniforme no prueban que alguien trabaje ahí, así que, si no se exige credencial en las áreas no públicas, cualquiera podría llegar hasta un computador con historias clínicas o a documentos de afiliados (REG-SI-07).
- **Integridad (3):** quien entra al centro de datos o a un cuarto técnico puede saltarse todos los controles informáticos: apagar un equipo, desconectar un cable, robarse un disco o conectar un dispositivo para espiar la red. Por eso estos cuartos deben estar cerrados con llave o con control electrónico, con registro de cada ingreso, cámaras y acompañamiento de los técnicos externos, para saber siempre quién estuvo ahí y cuándo (REG-SI-08).

ACT-10. Personal clave: administradores de TI y personal con acceso a historias clínicas (Personas)

Son las personas que tienen accesos privilegiados, lógicos o físicos, o que manejan información sensible todos los días. El responsable es el Director de Talento Humano, con apoyo de Seguridad de la Información (supuesto). A las personas no se les asigna una clasificación de información como tal. Las valoramos por la información a la que tienen acceso, que llega hasta el nivel **Reservada**. Valoración: C = 3, I = 2, D = 3, total 8, criticidad **Alta**.

Lo incluimos porque las personas también son activos: tienen el conocimiento y los accesos. Si un administrador cae en un engaño, sus permisos quedan en manos del atacante. Si la empresa depende de pocas personas que conocen los sistemas, su ausencia afecta la operación. Además, aquí está el riesgo del colaborador que consulta historias clínicas por curiosidad. Su credencial de ingreso a las áreas no públicas se regula en la REG-SI-07.

3. Identificación de vulnerabilidades

Una vulnerabilidad es una debilidad de un activo que una amenaza puede aprovechar para causar daño. A partir del inventario se revisó cada activo en cuatro frentes: software, hardware, físico-ambiental y humano-organizativo. El resultado son **14 vulnerabilidades**: diez técnicas con código CVE (V-01 a V-10), cinco de software y cinco de hardware, y cuatro sin CVE (V-11 a V-14), porque el catálogo CVE solo registra fallas de productos tecnológicos.

Aclaración. No se tuvo acceso a la infraestructura de EPS Sanitas. Las tecnologías mencionadas y las debilidades sin CVE son supuestos del equipo basados en problemas comunes del sector salud. Por eso no se afirma que la EPS sea vulnerable: se plantea que, si tuviera esa tecnología sin actualizar o esa debilidad sin controlar, estaría expuesta.

3.1 Referencias y escala utilizadas

- **CVE** (Common Vulnerabilities and Exposures): identifica una falla concreta en una versión concreta de un producto. Se consultó en la National Vulnerability Database (NVD) del NIST y en los avisos de cada fabricante.
- **CWE** (Common Weakness Enumeration, de MITRE): identifica el tipo de debilidad, sin depender de un producto (por ejemplo, CWE-311 falta de cifrado).
- **Regla o control:** para lo físico, humano y organizativo se indica la regla del punto 1 y el control del Anexo A de la ISO/IEC 27001:2022.

La gravedad se calificó con el **CVSS v3.1** (Common Vulnerability Scoring System) de FIRST. Su puntaje base se calcula así:

$$ISS = 1 - [(1 - C) \times (1 - I) \times (1 - A)]$$

$$\text{Impacto} = \begin{cases} 6.42 \times ISS & \text{si } S = U \\ 7.52 \times (ISS - 0.029) - 3.25 \times (ISS - 0.02)^{15} & \text{si } S = C \end{cases}$$

$$\text{Explotabilidad} = 8.22 \times AV \times AC \times PR \times UI$$

$$\text{Puntuación base} = \begin{cases} 0 & \text{si Impacto} \leq 0 \\ \text{mín}(\text{Impacto} + \text{Explotabilidad},\ 10) & \text{si } S = U \\ \text{mín}(1.08 \times (\text{Impacto} + \text{Explotabilidad}),\ 10) & \text{si } S = C \end{cases}$$

El resultado se redondea hacia arriba a un decimal, como lo publica la NVD. Los valores de cada métrica son fijos y están definidos por FIRST:

Métrica	**Valores**
AV – Vector de ataque	Red (N) 0.85 · Adyacente (A) 0.62 · Local (L) 0.55 · Físico (P) 0.20
AC – Complejidad del ataque	Baja (L) 0.77 · Alta (H) 0.44
PR – Privilegios requeridos	Ninguno (N) 0.85 · Bajos (L) 0.62 (0.68 si $S = C$) · Altos (H) 0.27 (0.50 si $S = C$)
UI – Interacción del usuario	Ninguna (N) 0.85 · Requerida (R) 0.62
C, I, A – Impacto	Alto (H) 0.56 · Bajo (L) 0.22 · Ninguno (N) 0
S – Alcance	Sin cambio (U) o cambiado (C); define la fórmula del impacto

Tabla 4: Valores de las métricas CVSS v3.1.

La gravedad se interpreta así: 0.1 a 3.9 Baja, 4.0 a 6.9 Media, 7.0 a 8.9 Alta y 9.0 a 10.0 Crítica. Para V-01 a V-10 se usó el vector oficial publicado (NVD; en V-08, el asignado por el fabricante AMI). Las vulnerabilidades sin CVE (V-11 a V-14) tienen un **puntaje estimado por el equipo**, no oficial, calculado con la misma fórmula eligiendo y justificando cada métrica; se usa solo para ordenar su gravedad y no modifica la probabilidad del riesgo, que se asigna con la escala del punto 4.

3.2 Resumen de vulnerabilidades por activo

Tabla 5: Las 14 vulnerabilidades identificadas.

ID	Activo	Tipo	Vulnerabilidad	Referencia	CVSS	Gravedad
V-01	ACT-03	Software	Falla en Veeam Backup & Replication que permite borrar o cifrar las copias de seguridad sin credenciales.	CVE-2024-40711	9.8	Crítica
V-02	ACT-04	Software	Log4Shell: una librería del portal permite ejecutar código enviando un texto manipulado.	CVE-2021-44228	10.0	Crítica
V-03	ACT-05	Software	Zerologon: falla en Netlogon que permite tomar el dominio sin contraseña.	CVE-2020-1472	10.0	Crítica
V-04	ACT-06	Software	MonikerLink: falla de Outlook que roba credenciales con un clic en un enlace.	CVE-2024-21413	9.8	Crítica
V-05	ACT-06, ACT-08	Hardware	Spectre v2: falla de diseño del procesador que permite leer memoria ajena.	CVE-2017-5715	5.6	Media
V-06	ACT-07	Hardware	Falla en el firmware de los firewalls FortiGate que permite tomarlos sin credenciales.	CVE-2024-21762	9.8	Crítica
V-07	ACT-08	Software	Falla de VMware ESXi que convierte una cuenta del dominio en administrador de los servidores.	CVE-2024-37085	7.2	Alta
V-08	ACT-08	Hardware	Falla en el firmware del BMC (AMI MegaRAC) que permite controlar los servidores a distancia.	CVE-2024-54085	10.0	Crítica
V-09	ACT-09	Hardware	TLStorm: falla en el firmware de las UPS APC que permite apagarlas o dañarlas.	CVE-2022-22805	9.8	Crítica
V-10	ACT-09	Hardware	Falla en cámaras y grabadores Hikvision que permite ver, borrar o apagar la videovigilancia.	CVE-2021-36260	9.8	Crítica
V-11	ACT-01, ACT-02	Software / organizativa	Protección insuficiente de los datos: permisos amplios, sin bitácora ni alertas, datos sin cifrar y datos reales en pruebas.	CWE-284; CWE-778; CWE-311; REG-SI-04; REG-SI-05	8.1*	Alta
V-12	ACT-10 (y ACT-06)	Humana	Prácticas inseguras y dependencia del personal: phishing, uso de IA pública o WhatsApp, descuido de equipos y pocos administradores.	A.6.3; A.5.37; REG-SI-03; REG-SI-06	8.8*	Alta
V-13	ACT-09 (y ACT-02)	Física	Control débil del ingreso: se acepta la bata como identificación, credenciales copiables y cuartos técnicos sin registro.	REG-SI-07; REG-SI-08; A.7.2; A.7.4	7.6*	Alta

ID	Activo	Tipo	Vulnerabilidad	Referencia	CVSS	Gravedad
V-14	ACT-09 (y ACT-07, ACT-08)	Ambiental	Dependencia de energía y climatización: UPS sin mantenimiento, planta sin pruebas y aire acondicionado sin respaldo.	A.7.11; A.7.5	6.1*	Media
(*) Puntaje estimado por el equipo con la fórmula oficial; no es un puntaje publicado.						

Todos los activos del inventario tienen al menos una vulnerabilidad: ACT-01 y ACT-02 (V-11), ACT-03 (V-01), ACT-04 (V-02), ACT-05 (V-03), ACT-06 (V-04 y V-05), ACT-07 (V-06), ACT-08 (V-05, V-07 y V-08), ACT-09 (V-09, V-10, V-13 y V-14) y ACT-10 (V-12). El desarrollo completo del cálculo CVSS de las 14 vulnerabilidades está en el Anexo B.

3.3 Detalle de las diez vulnerabilidades con CVE

Como pide el enunciado, cada ficha incluye el producto afectado, la descripción de la vulnerabilidad, su impacto, el puntaje CVSS, la posible relación con las tecnologías de la EPS, las medidas de mitigación y las fuentes oficiales. El tipo y el activo de cada vulnerabilidad están en la tabla anterior.

V-01. CVE-2024-40711: deserialización insegura en Veeam Backup & Replication

Producto afectado: Veeam Backup & Replication 12.1.2.172 y versiones anteriores.

Descripción: El software de copias de seguridad procesaba de forma insegura ciertos datos que recibía por la red (deserialización de datos no confiables). Un atacante sin autenticarse podía aprovecharlo para ejecutar código en el servidor de backups.

Impacto: Deja al atacante borrar o cifrar las copias de seguridad antes de atacar el resto de los sistemas, y la empresa queda sin cómo recuperarse. Sophos reportó que los grupos de ransomware Akira y Fog la usaron en ataques reales. CISA la agregó al catálogo KEV en octubre de 2024.

CVSS: 9.8, crítica.

Posible relación con la EPS: Veeam es uno de los programas de copias de seguridad más usados en empresas que virtualizan con VMware. Si la EPS lo usara en una versión anterior a la 12.2, su última defensa contra el ransomware quedaría expuesta.

Mitigación: Actualizar a Veeam Backup & Replication 12.2 o posterior; separar el servidor de backups de la red general y no unirlo al dominio; mantener al menos una copia inmutable o fuera de línea, siguiendo la regla 3-2-1.

Fuentes: NVD; boletín de seguridad de Veeam (septiembre de 2024); catálogo KEV de CISA; reportes de Cyble y Security Affairs.

V-02. CVE-2021-44228 "Log4Shell": ejecución remota de código en Apache Log4j

Producto afectado: Apache Log4j 2, en las versiones 2.0-beta9 a 2.14.1. Es una librería de Java para registrar eventos, y viene incluida dentro de miles de aplicaciones web y productos comerciales.

Descripción: Si una aplicación registra en sus logs un texto que el atacante controla, como un campo de un formulario o el encabezado de una petición, ese texto puede hacer que Log4j descargue y ejecute código desde un servidor del atacante.

Impacto: El atacante podría tomar el control del servidor web y desde ahí llegar a las bases de datos de afiliados e historias clínicas (ACT-01 y ACT-02). Es considerada una de las vulnerabilidades más graves de la historia por lo fácil de explotar y lo extendida que estaba. Está en el catálogo KEV.

CVSS: 10.0, crítica, el puntaje máximo.

Posible relación con la EPS: Los portales transaccionales grandes, como el de una EPS, suelen estar hechos en Java o usar productos que incluyen Log4j. No sabemos con qué tecnología está construido el portal de Sanitas. La incluimos porque, aunque es de 2021, todavía aparece en auditorías dentro de librerías que nadie revisó.

Mitigación: Actualizar Log4j a 2.17.1 o posterior; mantener un inventario de componentes de software (SBOM) para saber qué aplicaciones usan esta librería; usar un firewall de aplicaciones web (WAF) que bloquee los intentos de explotación.

Fuentes: NVD; página de seguridad de Apache Log4j; catálogo KEV de CISA; análisis de Snyk.

V-03. CVE-2020-1472 "Zerologon": elevación de privilegios en Netlogon

Producto afectado: Microsoft Windows Server con rol de controlador de dominio. También afecta a Samba cuando actúa como controlador de dominio.

Descripción: Es una falla en el protocolo Netlogon, que usan los equipos para autenticarse ante el controlador de dominio. Por un error en el uso de la criptografía (AES-CFB8 con un vector de inicialización en ceros), un atacante dentro de la red puede hacerse pasar por un equipo sin conocer ninguna contraseña, cambiar la contraseña del propio controlador de dominio y quedar como administrador del dominio.

Impacto: El atacante tomaría el control de toda la red de la empresa: usuarios, permisos y equipos. Fue muy usada por grupos de ransomware después de su publicación. Está en el catálogo KEV.

CVSS: 10.0, crítica, el puntaje máximo, según el NVD.

Posible relación con la EPS: Casi todas las empresas medianas y grandes usan Directorio Activo de Microsoft para gestionar a sus empleados. Aunque es de 2020, la incluimos porque en las auditorías todavía se encuentran servidores sin parchear. Muestra además que las contraseñas fuertes de la REG-SI-01 no bastan si el servidor que las valida tiene una falla.

Mitigación: Aplicar las actualizaciones de Microsoft de agosto de 2020 y febrero de 2021; esta última obliga a usar el canal seguro en todos los equipos; retirar los controladores de dominio con sistemas operativos sin soporte; monitorear los eventos de Netlogon que Microsoft indicó para detectar intentos de explotación.

Fuentes: NVD; guía de actualización de seguridad de Microsoft (MSRC); catálogo KEV de CISA; ficha de Wiz.

V-04. CVE-2024-21413 "MonikerLink": ejecución remota de código en Microsoft Outlook

Producto afectado: Microsoft Outlook en Microsoft 365 Apps for Enterprise, Office 2016, Office 2019 y Office LTSC 2021, antes de la actualización de febrero de 2024.

Descripción: Outlook no validaba bien cierto tipo de enlaces dentro de los correos. Con un enlace manipulado, el atacante podía saltarse la "Vista protegida" de Office y así robar las credenciales NTLM del usuario o ejecutar código, con un solo clic, incluso desde el panel de vista previa.

Impacto: Un correo de phishing bien hecho le bastaría al atacante para quedarse con las credenciales de un colaborador o tomar control de su equipo. CISA la agregó al catálogo KEV en 2025 por explotación activa.

CVSS: 9.8, crítica.

Posible relación con la EPS: Las empresas colombianas usan mucho Microsoft 365 y Outlook, y el personal de una EPS recibe todos los días correos con adjuntos y enlaces (autorizaciones, soportes, facturas de IPS). Esta falla técnica se suma a la vulnerabilidad humana del phishing (V-12).

Mitigación: Instalar las actualizaciones de Office de febrero de 2024 o posteriores; bloquear el tráfico SMB (puerto TCP 445) hacia internet; capacitar al personal para reconocer el phishing.

Fuentes: NVD; guía de actualización de seguridad de Microsoft (MSRC); investigación de Check Point Research; catálogo KEV de CISA.

V-05. CVE-2017-5715 "Spectre variante 2": fuga de información por ejecución especulativa en los procesadores

Producto afectado: Procesadores que usan ejecución especulativa y predicción de saltos, entre ellos la mayoría de los Intel y AMD fabricados durante años y algunos ARM. Están tanto en servidores como en portátiles y computadores de escritorio.

Descripción: Para ir más rápido, el procesador "adivina" qué instrucciones vienen y las ejecuta por adelantado. Un programa malicioso puede engañar esa predicción para que el procesador ejecute por adelantado instrucciones que leen memoria ajena. Aunque el resultado se descarta, deja rastros en la memoria caché que el atacante puede medir y así deducir datos (ataque de canal lateral). Es una falla del diseño físico del chip, no de un programa.

Impacto: Un atacante que ya ejecute código en el equipo podría leer información de otros programas. En servidores virtualizados es más grave: los investigadores de Google Project Zero demostraron que desde una máquina virtual se podía leer memoria del servidor anfitrión. Solo afecta la confidencialidad; no permite cambiar datos ni apagar equipos.

CVSS: 5.6, media, según el NVD (vector AV:L/AC:H/PR:L/UI:N/S:C/C:H/I:N/A:N). El puntaje es medio porque el atacante necesita acceso local previo y el ataque es difícil de ejecutar. No aparece en el catálogo KEV.

Posible relación con la EPS: Cualquier servidor o computador de la EPS con procesadores de esa época, sin el microcódigo y las actualizaciones correspondientes, estaría expuesto. La incluimos porque representa un tipo de falla que solo se corrige actualizando el firmware (BIOS/UEFI) o reemplazando el equipo, lo que obliga a llevar un control del hardware y de su vida útil.

Mitigación: Instalar las actualizaciones de BIOS/UEFI con el microcódigo corregido que publica el fabricante del equipo; mantener actualizados el sistema operativo y el hipervisor, que incluyen protecciones contra esta técnica; reemplazar los equipos que ya no reciben actualizaciones de firmware y no ubicar en el mismo servidor físico máquinas virtuales de distinto nivel de confianza.

Fuentes: NVD; aviso de seguridad de Intel INTEL-SA-00088; publicación de Google Project Zero (enero de 2018); ficha de Tenable.

V-06. CVE-2024-21762: escritura fuera de límites en el firmware FortiOS de los firewalls FortiGate

Producto afectado: Equipos FortiGate de Fortinet, es decir, los firewalls físicos que se instalan en los racks, con su firmware FortiOS en las ramas 6.0 a 7.4.2. También afecta a FortiProxy.

Descripción: Es una falla en el servicio de VPN SSL del equipo. Un atacante, sin tener usuario ni contraseña, puede enviar peticiones HTTP manipuladas que escriben fuera de la memoria permitida y así ejecutar código o comandos en el firewall.

Impacto: El atacante tomaría el control del equipo que protege la frontera de la red. Desde ahí podría entrar a la red interna, robar información o instalar ransomware. Está en el catálogo KEV de CISA.

CVSS: 9.8, crítica, según el NVD (vector AV:N/AC:L/PR:N/UI:N).

Posible relación con la EPS: Con el trabajo remoto, una EPS necesita una VPN, y FortiGate es uno de los firewalls más usados en empresas de Latinoamérica. Aunque se aplique la REG-SI-01 (segundo factor en todo acceso remoto), esta falla no se detiene con eso, porque el atacante no necesita autenticarse; por eso actualizar el firmware es indispensable.

Mitigación: Actualizar FortiOS a 7.4.3, 7.2.7, 7.0.14, 6.4.15 o 6.2.16 o posterior, según la rama. La rama 6.0 debe migrarse a una versión corregida; si no se puede actualizar de inmediato, deshabilitar la VPN SSL, como recomendó el fabricante; revisar los registros del equipo en busca de señales de compromiso.

Fuentes: NVD; aviso de Fortinet FG-IR-24-015; catálogo KEV de CISA; ficha de Tenable.

V-07. CVE-2024-37085: evasión de autenticación en VMware ESXi integrado con Active Directory

Producto afectado: VMware ESXi configurado para que sus administradores se gestionen desde Active Directory.

Descripción: ESXi les da permisos de administrador automáticamente a los miembros de un grupo del Directorio Activo llamado “ESX Admins”. Si ese grupo no existe o se borra, un atacante con ciertos permisos en el dominio puede crearlo, meterse en él y quedar como administrador total de los servidores ESXi.

Impacto: Microsoft reportó que grupos de ransomware como Black Basta y Akira la usaron para tomar el control de los servidores y cifrarlos. Al cifrar un solo servidor se caen todas las máquinas virtuales que aloja. Está en el catálogo KEV.

CVSS: 7.2, alta, según el NVD. VMware le dio 6.8. El puntaje no es tan alto porque el atacante ya necesita tener algunos permisos en el dominio, pero convierte el acceso a una cuenta en el control de todo el centro de datos.

Posible relación con la EPS: Si la EPS integrara sus servidores ESXi con su Directorio Activo, algo muy común para centralizar usuarios, un atacante que comprometa una cuenta del dominio podría escalar hasta los servidores.

Mitigación: Actualizar a ESXi 8.0 Update 3 o posterior; en las versiones sin parche, cambiar la configuración avanzada de ESXi para que no confíe automáticamente en ese grupo, siguiendo la guía del fabricante; vigilar la creación o modificación de grupos con privilegios en el Directorio Activo.

Fuentes: NVD; aviso VMSA-2024-0013 de Broadcom/VMware; catálogo KEV de CISA; reporte de Microsoft Threat Intelligence (julio de 2024).

V-08. CVE-2024-54085: evasión de autenticación en el controlador BMC de los servidores (AMI MegaRAC SPx)

Producto afectado: Firmware AMI MegaRAC SPx, versiones 12.0 a 12.6 y 13.0 a 13.4. Es el firmware del BMC (Baseboard Management Controller), un pequeño computador dentro de la placa del servidor que permite encenderlo, apagarlo y administrarlo a distancia, incluso cuando el sistema operativo está apagado. Lo usan fabricantes de servidores como HPE, Lenovo, ASUS, Gigabyte y Supermicro en algunos de sus modelos.

Descripción: La interfaz de administración Redfish del BMC no verificaba bien de dónde venían las peticiones. Cambiando ciertos encabezados HTTP, un atacante remoto podía saltarse por completo la autenticación, sin usuario ni contraseña.

Impacto: El atacante controlaría el servidor "por debajo" del sistema operativo: podría apagarlo o reiniciarlo en bucle, instalar malware o ransomware, alterar el firmware para que la infección sobreviva aunque se reinstale todo, e incluso dañar componentes de la placa. CISA la agregó al catálogo KEV en junio de 2025; fue la primera vulnerabilidad de un BMC en ese catálogo.

CVSS: 10.0, crítica, el puntaje máximo (asignado por AMI).

Posible relación con la EPS: Todos los servidores físicos del centro de datos tienen un BMC, y su puerto de administración suele conectarse a una red de gestión. La incluimos porque muestra que proteger el sistema operativo y el hipervisor no basta: el hardware del servidor tiene su propio "cerebro" que también puede ser atacado. Además, quien entre al cuarto técnico (V-13) podría conectarse directamente a ese puerto.

Mitigación: Actualizar el firmware del BMC a las versiones corregidas (SPx 12.7 o 13.5), que se distribuyen a través del fabricante de cada servidor; conectar los BMC solo a una red de gestión separada y nunca exponerlos a internet; deshabilitar la interfaz Redfish si no se usa y revisar periódicamente los registros del BMC.

Fuentes: NVD; aviso de seguridad de AMI (marzo de 2025); investigación de Eclypsium; catálogo KEV de CISA; advertencia de Censys; Network World.

V-09. CVE-2022-22805 (TLStorm): desbordamiento de memoria en UPS APC Smart-UPS

Producto afectado: UPS APC Smart-UPS de Schneider Electric con la función de conexión a la nube SmartConnect (series SMT, SMC, SMTL, SCL y SMX con firmware anterior a la versión corregida).

Descripción: Es un desbordamiento de búfer en la forma en que la UPS procesa los paquetes TLS de su conexión con la nube del fabricante. Un atacante remoto, sin autenticarse y sin que nadie haga nada, puede ejecutar código dentro de la UPS. Hace parte de un grupo de tres fallas llamado "TLStorm", junto con CVE-2022-22806 (evasión de autenticación) y CVE-2022-0715 (actualización de firmware sin firma válida).

Impacto: El atacante podría apagar la UPS o alterar su funcionamiento. Los investigadores de Armis demostraron que incluso podían dañarla físicamente hasta dejarla inservible. Si la UPS del centro de datos se apaga, los servidores y equipos de red quedan sin respaldo y un corte de luz los apaga de golpe. No aparece en el catálogo KEV: fue descubierta por investigadores y corregida antes de conocerse ataques.

CVSS: 9.8, crítica, según el NVD. Schneider Electric y Armis la califican con 9.0.

Posible relación con la EPS: APC es una de las marcas de UPS más usadas en centros de datos y clínicas; según Armis, sus equipos están muy presentes en el sector salud. Muestra que, ante un corte de luz, no basta con tener UPS, también hay que protegerla.

Mitigación: Instalar las actualizaciones de firmware publicadas por Schneider Electric (aviso SEVD-2022-067-02); si no se usa la conexión a la nube SmartConnect, deshabilitarla; conectar la tarjeta de administración de las UPS solo a una red de gestión separada y cambiar las contraseñas por defecto.

Fuentes: NVD; aviso de Schneider Electric SEVD-2022-067-02; investigación TLStorm de Armis; The Hacker News; ficha de Tenable.

V-10. CVE-2021-36260: inyección de comandos en cámaras y grabadores Hikvision

Producto afectado: Cámaras IP y grabadores de video (NVR) de Hikvision con firmware anterior a la actualización de septiembre de 2021.

Descripción: El servidor web interno de la cámara no valida bien los datos que recibe. Un atacante, sin usuario ni contraseña, puede enviar un mensaje manipulado y ejecutar comandos en el equipo, tomando el control total.

Impacto: El atacante podría ver o borrar las grabaciones, apagar las cámaras de un área crítica o usar la cámara como puerta de entrada a la red interna. Fue usada por redes de equipos infectados (botnets) como Moobot. Está en el catálogo KEV.

CVSS: 9.8, crítica, según el NVD (vector AV:N/AC:L/PR:N/UI:N).

Posible relación con la EPS: Hikvision es una de las marcas de cámaras más vendidas en Colombia y Latinoamérica. La REG-SI-08 exige cámaras en el centro de datos y en los cuartos técnicos; si esas cámaras

tuvieran esta falla, el propio control físico se volvería un punto débil: alguien podría apagarlas antes de entrar o borrar el video después.

Mitigación: Actualizar el firmware de las cámaras y grabadores a la versión corregida publicada por Hikvision; no exponer las cámaras ni los grabadores a internet; ponerlos en una red separada (VLAN) solo para videovigilancia; cambiar las contraseñas por defecto y guardar copia de las grabaciones de las áreas críticas fuera del grabador.

Fuentes: NVD; aviso de seguridad de Hikvision (septiembre de 2021); catálogo KEV de CISA; ficha de Tenable; análisis de Tesorion.

3.4 Detalle de las cuatro vulnerabilidades sin CVE

V-11. Protección insuficiente de los datos de afiliados y de las historias clínicas

Activos afectados: ACT-01, ACT-02 (vulnerabilidad software / organizativa).

Descripción: Agrupa las debilidades de cómo se guarda y se consulta la información más sensible de la EPS: (1) control de acceso por rol mal definido, de modo que cualquier persona del área asistencial puede abrir cualquier historia clínica aunque el paciente no esté a su cargo (CWE-284); (2) registro insuficiente, sin bitácora de quién abrió cada historia ni alertas ante consultas raras (CWE-778); (3) datos guardados sin cifrar en la base y en sus exportaciones (CWE-311); y (4) copias con datos reales en ambientes de pruebas y analítica, que tienen menos protección que producción.

Por qué la incluimos: Son información, así que no tienen una CVE propia: su debilidad está en los permisos, el registro y el manejo de las copias. Por eso las identificamos con el tipo de debilidad (CWE) y con las reglas REG-SI-04 y REG-SI-05.

Referencia: CWE-284; CWE-778; CWE-311; REG-SI-04; REG-SI-05.

CVSS estimado por el equipo: 8.1, alta (vector AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N). Se aprovecha desde la red interna (N), es fácil (L), la usa un usuario interno con una cuenta normal (L), no requiere que nadie más intervenga (N), el daño queda en el mismo sistema (U), expone y permite alterar datos de salud (C y I altos) y no tumba el servicio (A ninguno).

Mitigación: Definir permisos por rol y por paciente asignado, registrar cada consulta y generar alertas automáticas (REG-SI-05); cifrar la base de datos y sus exportaciones; usar datos enmascarados en pruebas y analítica (REG-SI-04).

V-12. Prácticas inseguras y dependencia del personal

Activos afectados: ACT-10 (y ACT-06) (vulnerabilidad humana).

Descripción: Agrupa las debilidades que dependen del comportamiento de las personas: (1) poca preparación frente al phishing y la ingeniería social; (2) uso de herramientas no autorizadas, como IA pública, WhatsApp o correo personal, para manejar datos de afiliados; (3) descuido de los equipos fuera de la oficina (trabajo en

lugares públicos, pérdida del celular sin reportarla); y (4) dependencia de pocos administradores que conocen los sistemas, sin documentación ni personal de respaldo.

Por qué la incluimos: Las personas no tienen CVE, pero los atacantes aprovechan estas debilidades tanto como una falla técnica: muchas de las CVE de este punto empiezan con un clic de un colaborador.

Referencia: A.6.3; A.5.37; REG-SI-03; REG-SI-06.

CVSS estimado por el equipo: 8.8, alta (vector AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H). El ataque llega por correo o mensajería (N), es barato y fácil (L), el atacante no necesita cuenta (N), pero requiere que el colaborador haga clic o entregue datos (R), y puede llevar a robo de datos, cambios y ransomware (C, I y A altos).

Mitigación: Capacitación periódica y simulacros de phishing (A.6.3); aplicar las reglas REG-SI-03 y REG-SI-06; documentar los procedimientos de administración y tener personal de respaldo para cada sistema crítico (A.5.37).

V-13. Control débil del ingreso físico a sedes, archivo y cuartos técnicos

Activos afectados: ACT-09 (y ACT-02) (vulnerabilidad física).

Descripción: En las áreas no públicas se acepta la bata o el uniforme como prueba de que alguien trabaja en la sede. Si las credenciales son tarjetas de proximidad de baja frecuencia (125 kHz), comunes por su bajo costo, se pueden copiar porque no tienen cifrado. Además, el centro de datos, los cuartos técnicos y el archivo de historias en papel se abren con llaves compartidas o quedan sin cerrar, sin registro de quién entra ni acompañamiento de los técnicos externos.

Por qué la incluimos: Quien entra a un cuarto técnico puede saltarse todos los controles informáticos (apagar equipos, robar un disco o conectar un dispositivo a la red), y quien llega a un consultorio puede ver historias clínicas.

Referencia: REG-SI-07; REG-SI-08; A.7.2; A.7.4.

CVSS estimado por el equipo: 7.6, alta (vector AV:P/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H). Hay que estar físicamente en la sede (P), basta una bata o una credencial copiada (L), no necesita cuenta ni ayuda de nadie (N y N), la debilidad está en el control de ingreso pero el daño pasa a servidores, red e historias clínicas (alcance C), y permite ver, manipular o apagar equipos (C, I y A altos).

Mitigación: Aplicar la REG-SI-07: credencial con fotografía en áreas no públicas y credencial temporal con acompañamiento para visitantes; aplicar la REG-SI-08: control electrónico con registro en el centro de datos, los cuartos técnicos y el archivo; usar credenciales con cifrado en lugar de tarjetas de baja frecuencia.

V-14. Dependencia del suministro eléctrico y de la climatización

Activos afectados: ACT-09 (y ACT-07, ACT-08) (vulnerabilidad ambiental).

Descripción: Las baterías de las UPS no reciben mantenimiento, la planta eléctrica no se prueba periódicamente y el aire acondicionado del centro de datos no tiene respaldo. Un corte de luz largo o un recalentamiento apaga de golpe los servidores, los equipos de red y los computadores de los consultorios.

Por qué la incluimos: Responde a la pregunta de qué pasa si se va la luz: la información deja de estar disponible aunque ningún atacante haya intervenido, y un apagado brusco puede dañar bases de datos que se estaban escribiendo.

Referencia: A.7.11; A.7.5.

CVSS estimado por el equipo: 6.1, media (vector AV:P/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:H). El evento ocurre en el sitio físico (P), sin mantenimiento basta un corte normal (L), no interviene ninguna cuenta ni persona (N y N), afecta a todos los sistemas del centro de datos (alcance C), no expone información (C ninguno), puede dañar algunas bases que se estaban escribiendo (I bajo) y detiene la operación (A alto).

Mitigación: Mantenimiento programado de UPS y planta eléctrica, con pruebas de transferencia de carga al menos cada trimestre (A.7.11); climatización redundante y alarmas de temperatura en el centro de datos.

4. Análisis y evaluación de riesgos

Se aplicó el proceso de gestión de riesgos de la ISO 31000:2018: identificación, análisis y evaluación. Se adoptó la estructura del Modelo de Gestión del Riesgo en Salud de EPS Sanitas (niveles improbable, probable e inminente), por ser el método que la propia entidad utiliza, y se añadieron dos niveles para complementar la escala, con criterios definidos conforme a la cláusula 6.3.4 de la ISO 31000:2018.

4.1 Escala de probabilidad

Nivel	Criterio (evidencia verificable)
Despreciable	No hay vulnerabilidad aplicable al activo o no existen las condiciones técnicas para el evento.
Improbable	Vulnerabilidad sin explotación conocida (fuera de KEV) que exige acceso local, privilegios previos o complejidad alta.
Posible	Vulnerabilidad sin explotación conocida pero explotable por red sin credenciales, o debilidad organizativa, humana o física sin antecedente público específico.
Probable	Vulnerabilidad en el catálogo KEV de CISA (explotación real confirmada) en la tecnología supuesta, o antecedente en el sector salud o en el grupo Keralty.
Inminente	El evento ya ocurre con frecuencia en el entorno normal (por ejemplo, correos de phishing diarios), además de existir la vulnerabilidad.

Tabla 6: Escala de probabilidad.

Reglas de uso:

1. Si un riesgo depende de varias vulnerabilidades, se usa la de la ruta más directa al evento. Las que solo lo facilitan no suben la probabilidad.
2. Las vulnerabilidades sin CVE (V-11 a V-14) no tienen CVSS oficial. Quedan en Posible por defecto y solo suben si hay evidencia de que el evento ya ocurre; eso se declara como supuesto.

4.2 Escala de impacto

Nivel	Datos y confidencialidad	Operación y atención	Legal y regulatorio
Leve	Datos no sensibles de menos de 100 titulares	1 a 4 h en servicio no crítico	Requerimiento informal
Moderada	Datos sensibles de menos de 1.000 titulares	4 a 24 h en servicio crítico	Requerimiento o investigación de la SIC o la Supersalud
Grave	Datos sensibles de 1.000 a 100.000 titulares	1 a 3 días, o pacientes sin atención o autorizaciones	Sanción económica o medidas de la Supersalud
Catastrófica	Más de 100.000 titulares o datos de salud masivos	Más de 3 días, o riesgo para la vida de pacientes	Sanciones máximas o intervención

Tabla 7: Escala de impacto.

Como en la guía de Sanitas, el criterio de operación mira el corto plazo (horas y días). Se complementó con criterios objetivos para cada nivel en las dimensiones de datos, operación y legal. **Regla de vínculo con el inventario:** si el activo afectado tiene valor 3 en la dimensión comprometida (C, I o D), la severidad mínima es Moderada.

4.3 Matriz de nivel de riesgo

Probabilidad \ Impacto	Leve	Moderada	Grave	Catastrófica
Inminente	Medio	Alto	Crítico	Crítico
Probable	Medio	Alto	Alto	Crítico
Posible	Bajo	Medio	Alto	Alto
Improbable	Bajo	Medio	Medio	Alto
Despreciable	Bajo	Bajo	Bajo	Medio

Tabla 8: Matriz de nivel de riesgo.

Nivel	Acción (alineada con la guía de Sanitas)
Bajo	No aplicar controles adicionales; monitorear.
Medio	Control vigilante: monitoreo, detección y seguimiento periódico.
Alto	Control mitigador: plan de tratamiento con responsable.
Crítico	Control mitigador prioritario: plan inmediato y reporte a la alta dirección.

Tabla 9: Acción según el nivel de riesgo.

La severidad se deriva de la valoración C, I, D del inventario. La matriz añade el nivel Crítico; la asignación de niveles es criterio propio y no un valor oficial de EPS Sanitas, lo cual permite la ISO 31000:2018 (cláusula 6.3.4) al dejar que cada organización defina sus criterios de riesgo.

4.4 Identificación de riesgos

Tabla 10: Identificación de riesgos.

ID	Activo(s)	Causa → Evento → Consecuencia	Vulnerabilidades	Regla relacionada
R01	ACT-08	Hipervisor o BMC sin parchear, o dominio comprometido → ransomware cifra el hipervisor → caen decenas de sistemas a la vez	V-01, V-03, V-06, V-07, V-08	REG-SI-01
R02	ACT-03	Servidor de backups vulnerable o accesible con credenciales de dominio → copias cifradas, borradas o inservibles → sin forma de recuperarse	V-01	REG-SI-01, 02, 08

ID	Activo(s)	Causa → Evento → Consecuencia	Vulnerabilidades	Regla relacionada
R03	ACT-05 (vinculado a ACT-10)	Credencial privilegiada robada o controlador de dominio sin parchear → toma del Directorio Activo → control de la red	V-03, V-12	REG-SI-01
R04	ACT-06, ACT-10	Phishing o enlace malicioso → credenciales robadas → acceso a correo y documentos, y salto a otros sistemas	V-04, V-12	REG-SI-01, 03
R05	ACT-07	Firmware del firewall sin parchear o VPN sin segundo factor → intrusión por el perímetro o caída → entrada a la red interna o corte de sedes	V-06	REG-SI-01, 06, 08
R06	ACT-04	Librería vulnerable o falta de protección web → exposición, alteración o caída del portal → afiliados sin trámites	V-02	Tratamiento
R07	ACT-01, ACT-02	Intrusión por el portal o el perímetro, o permisos y datos sin cifrar → exfiltración y publicación de datos → afectación masiva de titulares y sanciones	V-02, V-06, V-11	REG-SI-03, 05
R08	ACT-01, ACT-02	Copias de datos reales en pruebas y analítica → filtración o uso indebido → afectación de titulares	V-11	REG-SI-04
R09	ACT-02, ACT-10	Accesos amplios sin bitácora ni alertas → consulta indebida de historias clínicas → violación de la reserva legal	V-11	REG-SI-05
R10	ACT-02, ACT-01	Permisos excesivos o error humano → alteración de datos clínicos o de afiliación → decisión médica errónea o afiliado sin servicio	V-11	REG-SI-05
R11	ACT-06	Equipo perdido, robado o infectado, sin cifrar → exposición de datos → fuga puntual o puerta de entrada	V-05, V-12	REG-SI-06
R12	ACT-10	IA pública, WhatsApp o correo personal con datos de afiliados → salida de datos del control de la EPS → fuga e incumplimiento de la Ley 1581	V-12	REG-SI-03
R13	ACT-10	Salida o ausencia de administradores sin respaldo ni documentación → pérdida de conocimiento operativo → demora en recuperar o administrar	V-12	Tratamiento
R14	ACT-03, ACT-06	Servicio en la nube mal configurado o no evaluado → datos expuestos o no disponibles → fuga o indisponibilidad	V-01, V-04	REG-SI-02
R15	ACT-09 (afecta ACT-07, ACT-08)	UPS vulnerable o sin mantenimiento, planta sin pruebas, climatización sin respaldo → corte de energía o recalentamiento → apagado brusco de servidores, red y sedes	V-09, V-14	Tratamiento

ID	Activo(s)	Causa → Evento → Consecuencia	Vulnerabilidades	Regla relacionada
R16	ACT-09, ACT-02	Bata aceptada como identificación, credenciales copiables, cuartos técnicos sin registro, cámaras vulnerables → ingreso no autorizado → consulta o robo de información, o manipulación de equipos	V-10, V-13	REG-SI-07, 08
R17	ACT-08	Firmware del BMC o procesador vulnerable → control del servidor por debajo del sistema operativo o fuga entre máquinas virtuales → compromiso de varios sistemas	V-05, V-08	REG-SI-08 y tratamiento

4.5 Valoración de riesgos (riesgo inherente)

Tabla 11: Valoración de los riesgos inherentes.

ID	Activo(s)	P	Justificación de P	I	Justificación de I	Nivel
R01	ACT-08 Servidores virtualizados	Probable	V-03, V-07 y V-08 están en KEV; V-03 y V-07 las usaron grupos de ransomware; ocurrió en Keralty en 2022	Catastrófica	ACT-08 (D = 3); aloja decenas de sistemas, por lo que su caída detiene varios servicios a la vez	Crítico
R02	ACT-03 Copias de seguridad	Probable	V-01 está en KEV y la usaron Akira y Fog	Catastrófica	ACT-03 (I = 3); sin copias no se recupera ningún activo de criticidad Alta	Crítico
R03	ACT-05 Directorio Activo (vinculado a ACT-10)	Probable	V-03 y V-07 están en KEV; V-12 aporta contraseñas débiles	Catastrófica	ACT-05 (C, I, D = 3); da control de toda la red	Crítico
R04	ACT-06 Puesto de trabajo digital, ACT-10 Personal clave	Inminente	V-04 está en KEV y el phishing llega a diario (supuesto declarado)	Grave	ACT-06 (C = 3); no se considera Catastrófica porque no administra otros activos	Crítico
R05	ACT-07 Red de comunicaciones	Probable	V-06 está en KEV, sin credenciales y en el perímetro	Catastrófica	ACT-07 (I, D = 3); de él depende la conexión de sedes y teletrabajo	Crítico

ID	Activo(s)	P	Justificación de P	I	Justificación de I	Nivel
R06	ACT-04 Portal y app de afiliados	Probable	V-02 está en KEV	Grave	ACT-04 (I, D = 3); los datos que hay detrás se tratan en R07	Alto
R07	ACT-01 Base de afiliados, ACT-02 Historias clínicas	Probable	V-02 y V-06 están en KEV; V-11 aporta permisos amplios y datos sin cifrar	Catastrófica	ACT-01 y ACT-02 (C = 3); expone información Reservada de forma amplia	Crítico
R08	ACT-01 Base de afiliados, ACT-02 Historias clínicas	Posible	V-11 es una debilidad sin CVE; D1 autoriza bases con datos sensibles para estadística e investigación	Grave	ACT-01 y ACT-02 (C = 3); sin ajuste	Alto
R09	ACT-02 Historias clínicas, ACT-10 Personal clave	Posible	V-11 es una debilidad sin CVE; no se evidencia monitoreo	Moderada	ACT-02 (C = 3); consulta puntual por evento	Medio
R10	ACT-02 Historias clínicas, ACT-01 Base de afiliados	Posible	V-11 es una debilidad sin CVE; no se evidencia mínimo privilegio	Grave	ACT-02 (I = 3); afecta la atención, por lo que no se reduce	Alto
R11	ACT-06 Puesto de trabajo digital	Posible	V-12 (debilidad humana); V-05 es Improbable y no es la ruta directa	Moderada	ACT-06 (C = 3); afecta a un solo equipo	Medio
R12	ACT-10 Personal clave	Inminente	V-12; el uso de IA y mensajería personal está extendido y D2 no lo regula (supuesto declarado)	Moderada	ACT-10 (C = 3); fuga acotada por evento	Alto
R13	ACT-10 Personal clave	Posible	V-12 (dependencia de pocos administradores)	Moderada	ACT-10 (D = 3); retrasa la recuperación, no detiene el servicio	Medio
R14	ACT-03 Copias de seguridad, ACT-06 Puesto de trabajo digital	Posible	Debilidades de configuración en la nube (V-01, V-04), sin CVE	Grave	ACT-03 (C = 3) y ACT-06; sin ajuste	Alto
R15	ACT-09 Instalaciones físicas (afecta ACT-07 y ACT-08)	Posible	V-09 no está en KEV; V-14 es una debilidad sin CVE	Catastrófica	ACT-09 (D = 3); de la energía dependen servidores, red y consultorios	Alto

ID	Activo(s)	P	Justificación de P	I	Justificación de I	Nivel
R16	ACT-09 Instalaciones físicas, ACT-02 Historias clínicas	Posible	V-13 es una debilidad sin CVE; V-10 está en KEV pero solo facilita (apagar cámaras)	Catastrófica	ACT-09 (C, I = 3); quien llega a un cuarto técnico se salta los controles lógicos	Alto
R17	ACT-08 Servidores virtualizados	Probable	V-08 está en KEV (junio de 2025); es la ruta directa	Catastrófica	ACT-08 (I, D = 3); control del servidor por debajo del sistema operativo	Crítico

La evaluación de los 17 riesgos sobre los 10 activos del inventario arrojó **7 riesgos Críticos, 7 Altos y 3 Medios**, sin riesgos Bajos, lo que es coherente con una EPS, donde casi toda la información está ligada a datos de salud o a la continuidad de la atención. Casi todas las vulnerabilidades técnicas que sustentan estos riesgos están en el catálogo KEV de CISA, es decir, han sido explotadas en ataques reales. Los riesgos físicos y ambientales (R15 y R16) quedan en nivel Alto: son menos frecuentes, pero su severidad es máxima porque de la energía y de los cuartos técnicos dependen casi todos los demás activos. Los riesgos Críticos y Altos requieren controles mitigadores con plan y responsable, y los Medios, controles vigilantes.

5. Matriz de evaluación y tratamiento del riesgo

Los plazos de tratamiento dependen del nivel inherente del riesgo:

Nivel inherente	Plazo	Seguimiento
Crítico	Contención en 30 días; cierre en 90 días	Reporte a la alta dirección
Alto	180 días	Plan con responsable
Medio	365 días	Control vigilante, revisión semestral

Tabla 12: Plazos según el nivel de riesgo inherente.

Reglas del riesgo residual esperado (propuesta del equipo, independiente de Sanitas):

1. Cada control independiente que corrige la causa o agrega una barrera baja la probabilidad un nivel, máximo dos.

2. Un control de contención o recuperación (copias inmutables, cifrado, respaldo eléctrico, enmascaramiento) baja la severidad un nivel.
3. Si la puerta de entrada está expuesta a internet (perímetro, portal o correo), la probabilidad baja como máximo un nivel, porque estas fallas se han explotado como día cero antes de existir parche.
4. La probabilidad no baja de Improbable ni la severidad de Leve, porque el riesgo no se elimina por completo.

5.1 Matriz A: riesgo, activos, amenaza y vulnerabilidades

Responde a la pregunta: ¿qué riesgo tiene la EPS y qué tan grave es hoy?

Tabla 13: Matriz A: evaluación del riesgo inherente.

ID	Activos	Amenaza	Vulnerabilidades (CVSS)	P	S	Nivel inherente
R01	ACT-08	Ransomware sobre el hipervisor	V-01 (9.8), V-03 (10.0), V-06 (9.8), V-07 (7.2), V-08 (10.0)	Probable	Catastrófica	Crítico
R02	ACT-03	Ransomware que destruye las copias	V-01 (9.8)	Probable	Catastrófica	Crítico
R03	ACT-05, ACT-10	Atacante con credencial privilegiada robada	V-03 (10.0), V-12 (8.8 est.)	Probable	Catastrófica	Crítico
R04	ACT-06, ACT-10	Phishing e ingeniería social	V-04 (9.8), V-12 (8.8 est.)	Inminente	Grave	Crítico
R05	ACT-07	Explotación remota del perímetro	V-06 (9.8)	Probable	Catastrófica	Crítico
R06	ACT-04	Ataque web: librería vulnerable, fuerza bruta o denegación de servicio	V-02 (10.0)	Probable	Grave	Alto
R07	ACT-01, ACT-02	Atacante externo: exfiltración y extorsión	V-02 (10.0), V-06 (9.8), V-11 (8.1 est.)	Probable	Catastrófica	Crítico
R08	ACT-01, ACT-02	Uso indebido de datos reales en pruebas	V-11 (8.1 est.)	Posible	Grave	Alto
R09	ACT-02, ACT-10	Personal interno: consulta indebida	V-11 (8.1 est.)	Posible	Moderada	Medio

ID	Activos	Amenaza	Vulnerabilidades (CVSS)	P	S	Nivel inherente
R10	ACT-02, ACT-01	Error humano o abuso de privilegios	V-11 (8.1 est.)	Posible	Grave	Alto
R11	ACT-06	Pérdida, robo o infección de equipos	V-05 (5.6), V-12 (8.8 est.)	Posible	Moderada	Medio
R12	ACT-10	Uso de herramientas no autorizadas	V-12 (8.8 est.)	Inminente	Moderada	Alto
R13	ACT-10	Salida o ausencia de personal clave	V-12 (8.8 est.)	Posible	Moderada	Medio
R14	ACT-03, ACT-06	Error de configuración o falla del proveedor de nube	V-01 (9.8), V-04 (9.8)	Posible	Grave	Alto
R15	ACT-09 (ACT-07, ACT-08)	Corte eléctrico, falla de climatización o ataque a la UPS	V-09 (9.8), V-14 (6.1 est.)	Posible	Catastrófica	Alto
R16	ACT-09, ACT-02	Intrusión física o ingeniería social presencial	V-10 (9.8), V-13 (7.6 est.)	Posible	Catastrófica	Alto
R17	ACT-08	Acceso a la red de gestión o físico, y explotación del BMC	V-05 (5.6), V-08 (10.0)	Probable	Catastrófica	Crítico

5.2 Matriz B: controles, tratamiento y riesgo residual

Responde a la pregunta: ¿qué se va a hacer, quién, cuándo y cómo queda el riesgo después? Los controles existentes son los ya estipulados por Sanitas en su política corporativa (D2); los controles propuestos son las reglas formuladas y los controles del Anexo A de la ISO/IEC 27001:2022.

Tabla 14: Matriz B: tratamiento y riesgo residual esperado.

ID	Controles existentes (D2)	Controles propuestos (reglas y Anexo A 2022)	Tratamiento	Responsable	Plazo	Residual (P / S / Nivel)
R01	PL08, PL12, PL13, PL15	Parcheo de hipervisor, BMC y firewall (A.8.8); segmentación y red de gestión separada (A.8.22); segundo factor y cuentas de administración únicas (REG-SI-01; A.8.5, A.8.2); acceso físico reforzado (REG-SI-08); antimalware/EDR (A.8.7); copias inmutables (A.8.13)	Mitigar + transferir	Jefe de Infraestructura TI (apoyo: Administrador de Plataformas y Jefe de SI)	30 / 90 días	Posible / Grave / Alto
R02	PL08, PL13	Parche de Veeam (A.8.8); servidor de copias fuera del dominio y con credenciales propias (A.8.2); copia inmutable o fuera de línea (3-2-1) con prueba semestral de restauración (A.8.13); evaluación de las copias en la nube (REG-SI-02; A.5.23); respaldos locales en áreas críticas (REG-SI-08)	Mitigar + transferir	Jefe de Infraestructura TI	30 / 90 días	Improbable / Grave / Medio
R03	PL05, PL06	Parches de Netlogon y ESXi (A.8.8); contraseñas generadas y segundo factor (REG-SI-01; A.5.17, A.8.5); cuentas privilegiadas separadas y grupo Protected Users (A.8.2); revisión trimestral de cuentas (A.5.18); alertas por cambios en grupos privilegiados (A.8.16)	Mitigar	Administrador de Plataformas TI (apoyo: Jefe de SI)	30 / 90 días	Improbable / Grave / Medio
R04	PL12, PL15; capacitación (OBJ-04)	Actualización de Office y bloqueo de salida del puerto 445 (A.8.8, A.8.20); segundo factor (REG-SI-01); filtrado de correo y web (A.8.23, A.8.7); capacitación y simulacros (A.6.3); bloqueo de reenvío externo en Microsoft 365 (A.8.9)	Mitigar	Coordinador de Soporte TI (apoyo: Jefe de SI y Director de Talento Humano)	30 / 90 días	Probable / Moderada / Alto
R05	PL05, PL08	Firmware de FortiOS actualizado o VPN SSL deshabilitada si no se puede (A.8.8); segundo factor en la VPN (REG-SI-01); administración solo desde red de gestión (A.8.22); revisión de registros (A.8.15, A.8.16); gestión de configuración (A.8.9)	Mitigar	Jefe de Seguridad de la Información (apoyo: Infraestructura TI)	30 / 90 días	Posible / Grave / Alto

ID	Controles existentes (D2)	Controles propuestos (reglas y Anexo A 2022)	Tratamiento	Responsable	Plazo	Residual (P / S / Nivel)
R06	PL08, PL10	Actualización de Log4j e inventario de componentes de software (A.8.8, A.8.28); WAF y límite de intentos de inicio de sesión (A.8.20, A.8.5); protección anti-DDoS (A.8.6); pruebas de seguridad (A.8.29)	Mitigar	Jefe de Canales Digitales	30 días (parche) / 180 días	Posible / Moderada / Medio
R07	PL06, PL12; medidas generales de D1	Cifrado de bases y exportaciones (A.8.24); permisos por rol y monitoreo (REG-SI-05); herramientas y canales autorizados (REG-SI-03; A.8.12); parches de portal y perímetro (A.8.8); plan de respuesta y notificación a la SIC (A.5.24 a A.5.26)	Mitigar + transferir	Jefe de SI (dueños del dato: Jefe de Gestión de Afiliaciones y Director Médico)	30 / 90 días	Posible / Grave / Alto
R08	PL10 (menciona “datos de prueba”)	Enmascaramiento o anonimización (REG-SI-04; A.8.11, A.8.33); separación de entornos (A.8.31); excepciones aprobadas por el responsable del dato	Evitar	Jefe de Infraestructura TI (apoyo: dueños del dato)	180 días	Improbable / Moderada / Medio
R09	PL05, PL08 (registro genérico)	Registro y alertas de accesos a historias clínicas, revisión trimestral (REG-SI-05; A.8.15, A.8.16); acceso por necesidad (A.5.15, A.8.3); confidencialidad y proceso disciplinario (A.6.6, A.6.4)	Mitigar (vigilante)	Director Médico (apoyo: Jefe de SI)	365 días	Improbable / Moderada / Medio
R10	PL05	Mínimo privilegio y segregación de funciones (A.5.3, A.5.15, A.5.18); bitácora y control de cambios en datos clínicos (A.8.15, A.8.32)	Mitigar	Director Médico (apoyo: Administrador de Plataformas)	180 días	Improbable / Moderada / Medio
R11	PL04, PL07	Cifrado de discos y celulares con borrado remoto (A.8.1, A.8.24); bloqueo de USB no autorizados (A.7.10); BIOS y sistema operativo al día (A.8.8); trabajo remoto y escritorio limpio (REG-SI-06; A.6.7, A.7.9, A.7.7)	Mitigar	Coordinador de Soporte TI	365 días	Improbable / Leve / Bajo
R12	PL04, PL09	Prohibición de IA pública y canales personales con datos de afiliados (REG-SI-03; A.5.10, A.5.14); prevención de fuga de datos (A.8.12); herramientas de IA aprobadas con datos anonimizados; capacitación (A.6.3)	Evitar + mitigar	Jefe de SI (apoyo: Director de Talento Humano)	180 días	Posible / Moderada / Medio

ID	Controles existentes (D2)	Controles propuestos (reglas y Anexo A 2022)	Tratamiento	Responsable	Plazo	Residual (P / S / Nivel)
R13	PL03, PL13	Procedimientos operativos documentados (A.5.37); personal de respaldo y formación cruzada (A.6.3)	Mitigar (vigilante)	Director de Talento Humano (apoyo: Jefe de Infraestructura TI)	365 días	Improbable / Leve / Bajo
R14	PL11 (no menciona la nube)	Evaluación previa de servicios en la nube (REG-SI-02; A.5.23, A.5.19, A.5.20); revisión de configuración de Microsoft 365 y de las copias (A.8.9); cifrado (A.8.24)	Mitigar	Jefe de Infraestructura TI (apoyo: Jefe de SI)	180 días	Improbable / Moderada / Medio
R15	PL07, PL13	Mantenimiento y pruebas trimestrales de UPS y planta (A.7.11); firmware de UPS y red de gestión separada (A.8.8, A.8.22); climatización redundante y alarmas (A.7.5, A.7.8); continuidad TIC con RTO y RPO (A.5.30)	Mitigar	Gerente de Infraestructura Física y Mantenimiento (apoyo: Infraestructura TI)	180 días	Improbable / Grave / Medio
R16	PL07	Credencial con foto y credencial temporal para visitantes (REG-SI-07; A.7.1 a A.7.3); control electrónico y registro en áreas críticas (REG-SI-08; A.7.2, A.7.4); cámaras actualizadas en red separada y copia del video fuera del grabador (A.7.4, A.8.22)	Mitigar	Gerente de Infraestructura Física (apoyo: Jefe de SI)	30 días (cámaras) / 180 días	Improbable / Grave / Medio
R17	PL07, PL08	Firmware del BMC corregido, versiones 12.7 o 13.5 (A.8.8); red de gestión separada (A.8.22); acceso físico a cuartos técnicos (REG-SI-08); BIOS y firmware al día (A.8.9)	Mitigar	Jefe de Infraestructura TI (apoyo: Gerente de Infraestructura Física)	30 / 90 días	Improbable / Grave / Medio

El tratamiento propuesto reduce los 7 riesgos Críticos a nivel Alto o Medio y deja **4 riesgos en nivel Alto residual, 11 en Medio y 2 en Bajo**. Los riesgos que permanecen en Alto (R01, R04, R05 y R07) tienen en común que su puerta de entrada está expuesta a internet o que su consecuencia es una paralización. La prioridad inmediata, dentro de los primeros 30 días, es aplicar los parches de las vulnerabilidades del catálogo KEV y exigir segundo factor en los accesos remotos y privilegiados. En 90 días se completan las copias inmutables, la segmentación y la red de gestión. Los riesgos físicos (R15 y R16) y los de datos y personal se tratan en 180 a 365 días. Esta reducción es una estimación del equipo y debe verificarse con pruebas una vez implementados los controles.

6. Mapa de calor

El mapa de calor ubica cada riesgo en la matriz de probabilidad e impacto. Para el riesgo inherente se tomó la valoración del punto 4.5, y para el residual, el resultado esperado de la Matriz B (punto 5.2), de modo que el mapa es una representación gráfica de decisiones ya justificadas. Colores: verde para Bajo, amarillo para Medio, naranja para Alto y rojo para Crítico. La fila Despreciable se mantiene aunque no tenga riesgos.

6.1 Mapa de calor del riesgo inherente

Probabilidad \ Impacto	**Leve**	**Moderada**	**Grave**	**Catastrófica**
Inminente	–	R12	R04	–
Probable	–	–	R06	R01, R02, R03, R05, R07, R17
Posible	–	R09, R11, R13	R08, R10, R14	R15, R16
Improbable	–	–	–	–
Despreciable	–	–	–	–

Tabla 15: Mapa de calor del riesgo inherente (antes del tratamiento).

La mayor concentración está en la casilla Probable–Catastrófica, con seis riesgos (R01, R02, R03, R05, R07 y R17) que comparten un patrón: se apoyan en vulnerabilidades del catálogo KEV y afectan activos de los que dependen muchos otros (servidores, copias, Directorio Activo y perímetro). El riesgo R04 (phishing) es Crítico por otra vía: su impacto es Grave, pero su probabilidad es Inminente porque los correos maliciosos llegan todos los días.

6.2 Mapa de calor del riesgo residual

El riesgo residual es el nivel esperado después de implementar los controles. Para moverlo se aplicaron las reglas del punto 5: cada control que corrige la causa baja la probabilidad un nivel; los controles de contención o recuperación bajan el impacto un nivel; y los riesgos con puerta de entrada expuesta a internet solo bajan un nivel de probabilidad.

Probabilidad \ Impacto	**Leve**	**Moderada**	**Grave**	**Catastrófica**
Inminente	–	–	–	–
Probable	–	R04	–	–
Posible	–	R06, R12	R01, R05, R07	–
Improbable	R11, R13	R08, R09, R10, R14	R02, R03, R15, R16, R17	–
Despreciable	–	–	–	–

Tabla 16: Mapa de calor del riesgo residual (después del tratamiento).

Nivel	**Inherente**	**Residual**	**Cambio**
Crítico	7	0	−7
Alto	7	4	−3
Medio	3	11	+8
Bajo	0	2	+2

Tabla 17: Comparación entre riesgo inherente y residual.

El tratamiento elimina los riesgos Críticos y desplaza la mayoría hacia la zona amarilla. Los cuatro riesgos que siguen en Alto (R01, R04, R05 y R07) no bajan más por una decisión consciente del equipo: todos tienen la puerta de entrada expuesta a internet (perímetro, correo o portal) o una consecuencia de paralización, y afirmar que quedarían en Medio sería sobrestimar la eficacia de los controles. Estos riesgos se aceptan en Alto con seguimiento mensual, y se recomienda transferir parte de su impacto económico mediante una póliza de ciberriesgo. Los riesgos R11 y R13 llegan a Bajo porque sus controles son sencillos: cifrar los equipos y documentar los procedimientos.

7. Plan de tratamiento de riesgos

Para priorizar las acciones se usaron los siguientes criterios:

- **Nivel del riesgo inherente:** los siete riesgos Críticos van primero, como exige la tabla de plazos del punto 5 (contención en 30 días y cierre en 90).
- **Cuántos riesgos reduce cada acción:** se prefirieron acciones que atacan varios riesgos a la vez.
- **Costo y complejidad:** se priorizó lo que la EPS puede hacer con lo que ya tiene; las compras nuevas se dejaron solo donde no había alternativa.
- **Evidencia de ataque real:** las vulnerabilidades del catálogo KEV se corrigen antes que las demás, porque son las que usan los atacantes.
- **Gravedad CVSS:** entre acciones del mismo nivel, primero se atienden las vulnerabilidades con mayor puntaje que se pueden explotar por red sin cuenta.

Con estos criterios, en lugar de 17 planes separados se definieron **ocho acciones**. Las primeras seis cubren los siete riesgos Críticos y las dos últimas cubren riesgos Altos que no dependen de la tecnología (uso de IA pública y seguridad física y eléctrica).

A1. Parcheo prioritario de vulnerabilidades KEV	
Riesgos que reduce	R01, R02, R03, R05, R07, R17
Controles ISO/IEC 27001:2022	A.8.8 Gestión de vulnerabilidades técnicas
Acciones concretas	Actualizar Veeam, controladores de dominio, ESXi, FortiOS, BMC y Log4j a las versiones corregidas. Crear una lista mensual de parches basada en el catálogo KEV y fijar plazos: 15 días para críticas y 30 para altas.
Responsable	Jefe de Infraestructura TI
Recursos	Personal interno; actualizaciones gratuitas del fabricante; ventanas de mantenimiento nocturnas.
Plazo	30 días (críticas); 90 días (proceso)
Indicador de cumplimiento	% de vulnerabilidades KEV corregidas en plazo (meta: 100 %).
Resultado esperado	Se cierran las fallas que hoy permiten entrar sin credenciales.

A2. Segundo factor en accesos remotos y privilegiados	
Riesgos que reduce	R01, R03, R04, R05
Controles ISO/IEC 27001:2022	A.8.5 Autenticación segura; A.5.17 Información de autenticación (REG-SI-01)
Acciones concretas	Activar MFA en la VPN, el correo y todas las cuentas de administración. Separar la cuenta de administrador de la cuenta de uso diario.
Responsable	Administrador de Plataformas TI
Recursos	Microsoft Authenticator (incluido en Microsoft 365); integración con FortiGate ya disponible.
Plazo	30 días (administradores); 90 días (todos)
Indicador de cumplimiento	% de cuentas con MFA (meta: 100 % privilegiadas, 95 % general).
Resultado esperado	Una contraseña robada deja de ser suficiente para entrar.

A3. Copias de seguridad 3-2-1 con copia inmutable	
Riesgos que reduce	R01, R02
Controles ISO/IEC 27001:2022	A.8.13 Copias de seguridad de la información
Acciones concretas	Sacar el servidor de copias del dominio y darle credenciales propias. Mantener una copia inmutable o fuera de línea. Hacer una prueba de restauración cada semestre y medir el tiempo.
Responsable	Jefe de Infraestructura TI
Recursos	Almacenamiento inmutable (función de Veeam o en la nube); costo moderado de almacenamiento.
Plazo	90 días
Indicador de cumplimiento	Prueba de restauración exitosa cada 6 meses; tiempo real de recuperación frente al objetivo.
Resultado esperado	La EPS puede recuperarse de un ransomware sin pagar rescate.

A4. Red de gestión separada	
Riesgos que reduce	R01, R05, R15, R16, R17
Controles ISO/IEC 27001:2022	A.8.22 Segregación de redes
Acciones concretas	Crear una VLAN de gestión para los BMC, las UPS, las cámaras y las interfaces de administración de firewall y servidores, sin salida a internet.
Responsable	Jefe de Seguridad de la Información
Recursos	Configuración en switches y firewall existentes; no requiere compra.
Plazo	90 días
Indicador de cumplimiento	N.º de interfaces de administración fuera de la red de gestión (meta: 0).
Resultado esperado	Un equipo comprometido en la red general no alcanza los puntos de control del centro de datos.

A5. Defensa contra phishing	
Riesgos que reduce	R04, R12
Controles ISO/IEC 27001:2022	A.6.3 Concienciación y formación; A.8.23 Filtrado web; A.8.7 Protección contra malware
Acciones concretas	Capacitación corta (30 minutos) cada trimestre y simulacros de phishing. Bloquear el reenvío automático a correos externos y el tráfico SMB hacia internet. Activar el botón “Reportar phishing” en Outlook.
Responsable	Coordinador de Soporte TI con Talento Humano
Recursos	Herramienta de simulacros gratuita o incluida en Microsoft 365; 30 minutos por colaborador al trimestre.
Plazo	90 días y luego trimestral
Indicador de cumplimiento	Tasa de clic en simulacros (meta: menor a 5 %); tasa de reporte (meta: mayor a 50 %).
Resultado esperado	Menos credenciales robadas y detección temprana de campañas.

A6. Protección de datos de afiliados e historias clínicas	
Riesgos que reduce	R07, R08, R09, R10
Controles ISO/IEC 27001:2022	A.8.24 Uso de criptografía; A.8.15 Registro; A.8.16 Monitoreo; A.8.11 Enmascaramiento (REG-SI-04, REG-SI-05)
Acciones concretas	Activar el cifrado de la base de datos y de las exportaciones. Encender la bitácora de accesos a historias clínicas, con alertas simples (más de 50 consultas por día o accesos fuera del horario). Usar datos enmascarados en pruebas.
Responsable	Jefe de SI con el Director Médico
Recursos	Funciones nativas del motor de base de datos y de la historia clínica; revisión trimestral por muestreo.
Plazo	90 días (cifrado); 180 días (monitoreo)
Indicador de cumplimiento	% de bases cifradas; revisiones trimestrales realizadas; alertas atendidas.
Resultado esperado	Una filtración expone datos ilegibles y las consultas indebidas se detectan.

A7. Uso de IA y canales autorizados	
Riesgos que reduce	R12
Controles ISO/IEC 27001:2022	A.5.10 Uso aceptable; A.5.14 Transferencia de información (REG-SI-03)
Acciones concretas	Publicar la regla REG-SI-03 en una página. Ofrecer una herramienta de IA corporativa aprobada y bloquear en la red las IA públicas para datos de afiliados.
Responsable	Jefe de SI con Talento Humano
Recursos	Licencia de IA corporativa (por ejemplo, incluida en Microsoft 365); filtrado web existente.
Plazo	180 días
Indicador de cumplimiento	% de colaboradores que firmaron la regla; N.º de bloqueos registrados.
Resultado esperado	El personal tiene una alternativa segura y deja de usar canales personales.

A8. Seguridad física y respaldo eléctrico	
Riesgos que reduce	R15, R16
Controles ISO/IEC 27001:2022	A.7.2 Ingreso físico; A.7.4 Monitoreo físico; A.7.11 Servicios de suministro (REG-SI-07, REG-SI-08)
Acciones concretas	Exigir credencial con foto en áreas no públicas. Poner control electrónico y registro en el centro de datos y los cuartos técnicos. Mantener y probar cada trimestre la UPS y la planta eléctrica, y actualizar el firmware de UPS y cámaras.
Responsable	Gerente de Infraestructura Física
Recursos	Contrato de mantenimiento existente; lectores de tarjeta para los cuartos críticos (costo moderado).
Plazo	30 días (firmware); 180 días (resto)
Indicador de cumplimiento	Pruebas trimestrales de planta realizadas; % de ingresos a cuartos técnicos registrados.
Resultado esperado	Ni un corte de luz ni una persona con bata dejan expuesta la información.

Cronograma de acciones

Fase	**Acciones**	**Por qué en este orden**
Días 1–30	A1 (parches críticos), A2 (MFA en administradores y VPN), A8 (firmware de UPS y cámaras)	Son las medidas más baratas y cierran las puertas que hoy permiten entrar sin credenciales.
Días 31–90	A2 (MFA a todos), A3, A4, A5, A6 (cifrado)	Requieren configuración y coordinación, pero no compras grandes. Al terminar, ningún riesgo queda Crítico.
Días 91–180	A6 (monitoreo), A7, A8 (control de acceso y mantenimiento)	Dependen de cambios en procesos y en la cultura del personal, que toman más tiempo.
Permanente	Parcheo mensual, simulacros trimestrales, pruebas de restauración semestrales	Los controles pierden efecto si no se mantienen.

Tabla 18: Cronograma del plan por fases.

El seguimiento lo hace el Jefe de Seguridad de la Información con un informe mensual de los indicadores a la alta dirección. Si un indicador no se cumple dos meses seguidos, el riesgo asociado vuelve a evaluarse con su nivel inherente.

8. Caso de incidente: ransomware

Se eligió un ataque de ransomware porque reúne los tres riesgos prioritarios del análisis (R04 phishing, R03 toma del Directorio Activo y R01 cifrado del hipervisor) y porque no es hipotético para el grupo: Keralty sufrió un ataque de este tipo en 2022. El caso es **ficticio** y sirve para comprobar si los controles del plan responden a un ataque real.

8.1 Escenario

Lunes, 9:00 a. m.: una auxiliar de autorizaciones recibe un correo que parece de una IPS con el asunto “Soporte de factura pendiente”. Hace clic en el enlace e ingresa su usuario y contraseña en una página falsa. Como la VPN no tiene segundo factor, el atacante entra a la red esa misma noche. Durante tres días explora la red, encuentra un controlador de dominio sin el parche de Zerologon y obtiene permisos de administrador. El jueves a las 2:00 a. m. borra las copias de Veeam, cifra los servidores ESXi y deja una nota de rescate. Antes de cifrar, copió parte de la base de afiliados y amenaza con publicarla (doble extorsión). En la mañana, las sedes reportan que no pueden abrir la historia clínica ni generar autorizaciones.

8.2 Cadena del ataque y plan que la habría cortado

Etapa del ataque	Riesgo	Vulnerabilidad y puntaje	Control que lo detiene
Correo de phishing y robo de contraseña	R04	V-04 (9.8)	A5: capacitación, filtrado y botón de reporte
Ingreso por VPN con la contraseña robada	R05	V-06 (9.8)	A2: segundo factor en la VPN
Toma del Directorio Activo con Zerologon	R03	V-03 (10.0)	A1: parche de Netlogon
Borrado de las copias de seguridad	R02	V-01 (9.8)	A3: copia inmutable fuera del dominio
Cifrado de los servidores ESXi	R01	V-07 (7.2)	A1 y A4: parche de ESXi y red de gestión
Robo y amenaza de publicar datos	R07	V-11 (8.1 est.)	A6: base de datos cifrada

Tabla 19: Cadena del ataque y controles del plan.

Se aplica la lógica de *defensa en capas*: el atacante necesita superar todas las etapas, mientras que la EPS solo necesita cortar una para frenar el daño.

8.3 Respuesta al incidente

La respuesta sigue las fases de la guía NIST SP 800-61 y el control A.5.26 (Respuesta a incidentes de seguridad de la información) de la ISO/IEC 27001:2022.

Contención (primeras 4 horas). Se prioriza aislar sobre seguir operando, porque mantener los sistemas conectados permitiría que el cifrado se extienda a más servidores. La atención no se detiene porque existe el procedimiento manual.

- Activar el equipo de respuesta: Jefe de SI (líder), Infraestructura TI, área jurídica y comunicaciones.
- Desconectar de la red los servidores afectados, pero no apagarlos, porque la memoria guarda evidencia que se pierde al apagar.
- Cerrar la VPN de forma temporal y desactivar la cuenta de la auxiliar y todas las cuentas de administrador que el atacante pudo usar.
- Activar el plan de contingencia: formatos en papel para autorizaciones urgentes y línea telefónica para que las IPS confirmen derechos.

Investigación (días 1 a 5). Es sostenible si existe la copia inmutable de la acción A3.

- Preservar la evidencia: copias de los discos y la memoria, registros del firewall, de la VPN, del Directorio Activo y de Veeam.
- Reconstruir la línea de tiempo: correo inicial, ingreso por VPN, uso de Zerologon, borrado de copias y cifrado.
- Determinar qué datos salieron y cuántos titulares están afectados para definir a quién se notifica.

Notificación.

- Reportar el incidente a la Superintendencia de Industria y Comercio (SIC) por tratarse de datos personales, conforme a la Ley 1581 de 2012.
- Informar a la Superintendencia Nacional de Salud por la afectación del servicio, y a ColCERT para recibir apoyo técnico.
- Comunicar a los afiliados afectados qué pasó, qué datos se expusieron y qué precauciones tomar.

Recuperación (días 2 a 10). El orden de restauración se basa en el inventario: primero lo que tiene disponibilidad 3 y afecta la atención de pacientes (ACT-02), y después lo que permite esperar.

- Reconstruir primero el Directorio Activo desde cero, porque no se puede confiar en el que controló el atacante.
- Restaurar desde la copia inmutable en este orden: historia clínica y autorizaciones, luego base de afiliados y portal, y al final los sistemas administrativos.
- Antes de volver a conectar cada sistema, aplicar los parches pendientes y verificar que no tenga rastros del atacante.
- Restablecer la VPN solo con segundo factor obligatorio y cambiar todas las contraseñas de la organización.

Prevención y lecciones aprendidas (días 10 a 30).

- Acelerar las acciones A1 a A5 del plan, que hubieran cortado el ataque en cinco puntos distintos.
- Actualizar el plan de respuesta y realizar un simulacro de ransomware.

Fase	Tiempo	Responsable	Resultado
Contención	0–4 horas	Jefe de SI e Infraestructura TI	El cifrado se detiene; atención en modo manual
Investigación	Días 1–5	Jefe de SI y forense externo	Se conoce la ruta del ataque y los datos afectados
Notificación	Según plazos legales	Jurídica y comunicaciones	Cumplimiento ante la SIC y la Supersalud
Recuperación	Días 2–10	Infraestructura TI	Servicios críticos restablecidos sin pagar rescate
Prevención	Días 10–30	Jefe de SI	Controles reforzados y plan actualizado

Tabla 20: Resumen de la respuesta al incidente.

9. Conclusiones

La seguridad de la información de la EPS depende de pocos puntos. Los tres riesgos prioritarios se escogieron porque, además de ser Críticos, son los que abren la puerta a los demás: si se controlan, se reduce de forma indirecta casi todo el resto del mapa de calor.

Riesgo prioritario 1: phishing y robo de credenciales (R04). Es el único riesgo con probabilidad Inminente y es el primer paso de la mayoría de los ataques. La EPS debería implementar el segundo factor de autenticación en correo y VPN, y capacitar al personal con simulacros cortos. Se justifica porque el segundo factor convierte una contraseña robada en un dato inútil para el atacante.

Riesgo prioritario 2: toma del Directorio Activo (R03). El Directorio Activo controla toda la red, por eso es el objetivo del atacante que ya entró. La EPS debería parchear los controladores de dominio dentro de los plazos de la acción A1, separar las cuentas de administración y revisar cada trimestre las cuentas activas. Se justifica porque son medidas de configuración interna, sin compras, y porque cortan el camino entre una cuenta comprometida y el control total de la empresa.

Riesgo prioritario 3: ransomware sobre servidores y copias (R01 y R02). Es el riesgo con mayor impacto, porque un solo servidor cifrado detiene decenas de sistemas y, sin copias, no hay recuperación. Ya ocurrió en el grupo Keralty en 2022. La EPS debería mantener una copia inmutable fuera del dominio, probarla cada semestre y separar la red de gestión de los servidores. Se justifica porque la copia inmutable es la única medida que garantiza recuperarse aunque fallen todas las demás, y permite tomar la decisión de no pagar rescate.

Reflexión final. El trabajo muestra tres ideas útiles para cualquier organización. Primero, la seguridad no se logra solo con tecnología: dos de las capas críticas son las personas y los espacios físicos con su energía. Segundo, no hace falta resolverlo todo a la vez: ocho acciones bien escogidas eliminan los siete riesgos Críticos en 90 días, y la mayoría usa recursos que la EPS ya tiene. Tercero, el riesgo nunca llega a cero: cuatro riesgos siguen en Alto, y por eso el plan incluye seguimiento mensual, pruebas reales de los controles y una póliza que transfiera parte del impacto.

Referencias

Congreso de Colombia. (1981). *Ley 23 de 1981, por la cual se dictan normas en materia de ética médica*.

Congreso de Colombia. (2012). *Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales*.

Ministerio de Salud. (1999). *Resolución 1995 de 1999, por la cual se establecen normas para el manejo de la historia clínica*.

Grupo Keralty. (2024). *Política de Privacidad y Tratamiento de Datos Personales* (D1; última modificación 13/02/2024).

Grupo Keralty. (2021). *Política corporativa de seguridad de la información y ciberseguridad*, versión 1.0 (D2). EPS Sanitas.

EPS Sanitas. (s. f.). *Modelo de Gestión del Riesgo en Salud*.

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements*.

International Organization for Standardization. (2018). *ISO 31000:2018 Risk management – Guidelines*.

National Institute of Standards and Technology. (2012). *Computer Security Incident Handling Guide* (NIST SP 800-61 Rev. 2).

FIRST. (2019). *Common Vulnerability Scoring System v3.1: Specification Document*. `https://www.first.org/cvss/v3.1/specification-document`

National Institute of Standards and Technology. (s. f.). *National Vulnerability Database*. `https://nvd.nist.gov/` (una entrada por cada CVE citado).

Cybersecurity and Infrastructure Security Agency. (s. f.). *Known Exploited Vulnerabilities Catalog*. `https://www.cisa.gov/known-exploited-vulnerabilities-catalog`

MITRE. (s. f.). *Common Weakness Enumeration (CWE)*. `https://cwe.mitre.org/`

Apache Software Foundation. (s. f.). *Apache Log4j Security Vulnerabilities*. `https://logging.apache.org/log4j/2.x/security.html`

Microsoft Security Response Center. (s. f.). *Security Update Guide: CVE-2020-1472 y CVE-2024-21413*. `https://msrc.microsoft.com/update-guide`

Broadcom/VMware. (2024). *VMSA-2024-0013 (CVE-2024-37085)*.

Cyble. (2024). *Critical vulnerability in Veeam products exploited by ransomware gangs*. `https://cyble.com/blog/critical-vulnerability-in-veeam-products-exploited-by-ransomware-gangs/`

Fortinet PSIRT. (2024). *FG-IR-24-015: Out-of-bound write in sslvpnd (CVE-2024-21762)*.

AMI. (2025). *Security advisory: MegaRAC SPx Redfish authentication bypass (CVE-2024-54085)*.

Censys. (2025). *CISA warning issued for AMI MegaRAC SPx (CVE-2024-54085)*. https://censys.com/advisory/cve-2024-54085/

Intel. (2018). *INTEL-SA-00088: Speculative execution and indirect branch prediction side channel analysis method*.

Schneider Electric. (2022). *Security Notification SEVD-2022-067-02: APC Smart-UPS (TLStorm)*.

Hikvision. (2021). *Security Notification – Command Injection Vulnerability in Some Hikvision Products*.

Tenable. (s. f.). Fichas de CVE-2017-5715, CVE-2021-36260, CVE-2022-22805, CVE-2024-21762 y CVE-2024-37085. https://www.tenable.com/cve